

PrivAudit: A Dual-Lens Auditing Framework for Website Privacy Practices under the CCPA

Mohamed Moustafa Dawoud
University of California, Santa Cruz
Santa Cruz, California, USA
mdawoud@ucsc.edu

Likith Rahul Krishnamurthy
University of California, Santa Cruz
Santa Cruz, California, USA
likrishn@ucsc.edu

Riya Aggarwal
University of California, Santa Cruz
Santa Cruz, California, USA
raggarw6@ucsc.edu

Ram Sundara Raman
University of California, Santa Cruz
Santa Cruz, California, USA
rsundar2@ucsc.edu

Abstract

Five years after the enforcement of the California Consumer Privacy Act (CCPA), understanding how website privacy practices evolve at scale in response to regulation remains a key challenge for both researchers and regulators. Prior work and regulatory efforts have focused on manual and case-specific enforcement, but there remain no scalable approaches to systematically audit two key user-facing facets of websites that are crucial signals for the CCPA: privacy disclosures and front-end user tracking behavior.

In this paper, we present PrivAudit, an automated auditing framework that adopts a dual-lens approach to capture: (1) privacy disclosures through large language model-based analysis of privacy policies grounded in CCPA provisions, and (2) user-observable data collection behavior through automated browser measurements of cookie writes under diverse privacy configurations. We apply PrivAudit to 998 websites and report two broad findings. The law is associated with stronger privacy disclosures: CCPA-subject policies are more likely to disclose opt-out mechanisms, data-sharing practices, and user rights. On the other hand, cookie-based tracking remains pervasive, with both CCPA-subject and not-subject websites setting a total of 6,392 targeting cookies, 49% of which are third-party writes. Moreover, cookies show limited-to-moderate responsiveness to privacy signals and consent choices, even when websites claim to honor them in their disclosures.

Our results highlight the need for multi-layered and scalable auditing approaches that combine policy analysis with behavioral evidence. PrivAudit can support these auditing workflows at scale by generating actionable signals and patterns for further manual review. We open-source PrivAudit and are engaging with regulators to support auditing in practice.

CCS Concepts

• **Security and privacy** → **Human and societal aspects of security and privacy; Privacy protections.**

Keywords

CCPA, privacy compliance, cookie tracking, Global Privacy Control, privacy policy analysis, web measurement, regulatory auditing

ACM Reference Format:

Mohamed Moustafa Dawoud, Riya Aggarwal, Likith Rahul Krishnamurthy, and Ram Sundara Raman. 2026. PrivAudit: A Dual-Lens Auditing Framework for Website Privacy Practices under the CCPA. In *Proceedings of the 2026 ACM SIGSAC Conference on Computer and Communications Security (CCS '26)*, November 15–19, 2026, The Hague, Netherlands. ACM, New York, NY, USA, 25 pages. <https://doi.org/10.1145/3830454.3846679>

1 Introduction

The California Consumer Privacy Act (CCPA), as amended by the California Privacy Rights Act (CPRA), is the first comprehensive consumer data privacy law in the United States [52]. The CCPA grants California residents the right to know what personal information businesses collect, to request its deletion, and to opt out of its sale or sharing with third parties. Unlike the opt-in model of the EU's General Data Protection Regulation (GDPR), which requires businesses to obtain consent *before* collecting data [112], the CCPA allows businesses to collect data by default and places the burden on users to opt out. To exercise this right, users can submit requests through website interfaces or send automated browser signals such as the Global Privacy Control (GPC), which CCPA-covered businesses must honor as an opt-out preference signal [56]. More than five years after the CCPA's enforcement, and as more than 20 U.S. states adopt similar privacy frameworks [53, 54, 68, 88], understanding how websites' privacy practices have evolved under the law, and how they can be audited at scale, remains an open challenge for both researchers and regulators.

Despite the growing importance of the CCPA, both regulatory enforcement and academic measurement remain limited in scope. Public enforcement actions by the California Attorney General have largely proceeded case by case, focusing on specific companies and documented practices such as undisclosed tracking and ineffective opt-out mechanisms [21, 22, 24, 28, 29]. This case-specific model is essential for legal enforcement, but difficult to scale to broad audits because regulators must manually evaluate potential violations [26]. Academic research has similarly examined isolated, point-in-time compliance questions, including opt-out link deployment [109, 116], dark patterns in consent interfaces [78, 87, 110], and downstream ad-tech behavior [10, 75]. Meanwhile, the more extensive GDPR



This work is licensed under a Creative Commons Attribution 4.0 International License.

CCS '26, November 15–19, 2026, The Hague, Netherlands

© 2026 Copyright held by the owner/author(s).

ACM ISBN 979-8-4007-2871-6/2026/11

<https://doi.org/10.1145/3830454.3846679>

literature has shown that tracking mechanisms can undermine user choice [15, 37, 77, 86]. The CCPA’s opt-out model [30, 87] has received less empirical scrutiny [14], particularly around the user-facing privacy practices.

Although this body of work provides a valuable foundation of website compliance with the CCPA, two important and inter-related gaps remain regarding privacy practices of websites: (1) the lack of scalable and practical methods to systematically analyze privacy policy disclosures under the CCPA, and (2) limited understanding of cookie writing practices for CCPA-subject and not-subject websites. Importantly, these two elements together provide *externally observable and complementary user-facing signals of website privacy practices* without privileged access, making them ideal for the *auditing* needs of California regulators [25], which involves multi-layered assessments of privacy practices and trends at scale across numerous sectors. This dual-lens view is also increasingly relevant to regulatory practice. Privacy policies are the primary interface through which websites communicate data practices, rights, and opt-out mechanisms. Cookie writes, in turn, often represent the first observable step in user data collection and can reveal whether tracking persists under privacy signals such as GPC. These dimensions are legally and practically connected. The CCPA defines personal information to include online identifiers such as cookies, pixel tags, and device identifiers (Cal. Civ. Code §1798.140 (aj)), and the CPRA regulates both the “sale” (§1798.140(ad)) and the “sharing” for cross-context behavioral advertising (§1798.140 (ah)) of such information, neither of which requires a monetary exchange; the CPRA correspondingly expanded the consumer’s opt-out right from the “sale” to the “sale or sharing” of personal information (§1798.120(a)) [105]. A third-party script that writes a cookie to store a consumer’s identifier can thus initiate the “sale” or “sharing” the statute regulates, making front-end cookie behavior an observable signal of CCPA-regulated conduct. Recent enforcement actions illustrate the importance of both dimensions [21–23, 29]. For example, Sephora paid \$1.2M in a settlement involving undisclosed third-party tracking technologies, including cookies, and GPC non-compliance [21]. In another example, Healthline paid \$1.55M in a case related to third-party sharing of health-related browsing data through cookies and pixels after opt-out, as well as cookie consent banners that falsely claimed to disable tracking [22]. Yet such investigations remain case-specific and resource-intensive, motivating scalable auditing methods that can surface disclosure and tracking signals across many websites.

To address this gap, we develop **PrivAudit**, a scalable dual-lens auditing framework for user-facing privacy practices under the CCPA. PrivAudit combines two complementary analyses for surfacing externally observable audit-relevant patterns. First, we develop a *privacy policy audit* that leverages expert-guided large language models (LLMs) to evaluate privacy disclosures against CCPA-grounded rubric dimensions validated through review by a privacy-law expert. We address key challenges in scalable auditing by automating privacy-policy extraction and validating LLM outputs against a human-labeled ground truth (97% agreement), with a Monte Carlo analysis confirming our findings are robust to LLM error. Second, we implement a browser-based *cookie audit* that measures first-visit tracking behavior under six different privacy configurations, including GPC, third-party cookie blocking,

and consent interactions. We synthesize multiple datasets to categorize cookie functionality and develop a script-based attribution approach to identify third-party cookies. We ultimately link these two views at the website level to detect disclosure-behavior gaps that prior single-lens approaches cannot detect [10, 109, 110, 116].

We apply PrivAudit to study 998 websites (933 privacy policies) with known CCPA subjectivity, comparing 602 CCPA-Subject websites against 396 CCPA-Not-Subject ones. Because the CCPA imposes disclosure and opt-out obligations only on businesses meeting its applicability thresholds, we use CCPA-Not-Subject websites as a descriptive comparison group. We also apply PrivAudit to a disjoint stratified sample of 1,000 popular websites from Tranco [94] without pre-established subjectivity labels as a case study.

We report three main results. First, *CCPA-Subject websites provide stronger privacy disclosures than CCPA-Not-Subject websites*. They are significantly more likely to describe opt-out mechanisms (77% vs. 57%), rights to access (85% vs. 68%) and delete data (86% vs. 69%), and support for GPC (29% vs. 13%). However, only a small fraction of policies provide detailed disclosures about specific practices, such as cookie consent behavior or honoring privacy signals. Notably, 43% of CCPA-Not-Subject websites also reference the CCPA in their policies, suggesting a spillover effect of the law.

Second, *stronger disclosures do not correspond to reduced third-party tracking*. Cookie writes remain widespread across both CCPA-Subject and CCPA-Not-Subject websites, with 6,392 Targeting cookies in total, almost half of which involve third-party writes. Many third-party cookies are set by scripts operating in the first-party context, and just 10 scripts from large advertising providers account for more than half of all tracking cookies. Privacy signals reduce but do not eliminate tracking: among CCPA-Subject websites, GPC reduces total tracking cookies by 55% and third-party tracking cookies by only 41%. Consent mechanisms are often absent [60], and when present, user choices have only a limited effect on cookies. Although the CCPA does not explicitly regulate cookie writes themselves, cookies serve as the primary front-end mechanism through which third-party data collection is initiated, and third-party tracking persisting beyond user privacy signals serves as an important auditing signal.

Third, *linking disclosures to cookie behavior reveals audit-relevant gaps*. Among CCPA-Subject websites whose policies claim to honor GPC, 39% show no reduction in Targeting cookies when GPC is sent, and more than half reduce Targeting cookies by less than 20%. The gap is wider for third-party Targeting cookies specifically: 66% show less than a 20% reduction and 47% show no reduction at all. Among CCPA-Subject websites that state they do not sell personal data, more than half still deploy third-party Targeting cookies at initial load. These findings also generalize across the popular websites without known subjectivity. These patterns alone are not evidence of legal violations, but they provide scalable auditing signals for deeper manual review.

These findings underscore the value of multi-lens auditing approaches that combine policy analysis with behavioral evidence. Complementing prior work that has focused on isolated studies of compliance, dark patterns, and data sales [10, 109, 110], PrivAudit derives scalable auditing signals that help identify websites, sectors, and practices that may warrant deeper investigation and follow-up enforcement. Although our study focuses on the CCPA, PrivAudit

is extensible to other state privacy laws that adopt similar disclosure, opt-out, and universal opt-out signal requirements [68]. We have open-sourced PrivAudit and all datasets¹, and are engaging with the California regulatory community to explore how it can support auditing in practice.

2 Background and Related Work

The California Consumer Privacy Act (CCPA). The CCPA, along with its amendment CPRA, which we jointly refer to as just “CCPA”, established one of the first comprehensive data privacy frameworks in the United States [52]. Unlike the GDPR’s strict opt-in regime [112], the CCPA adopts an opt-out model: businesses may collect personal information by default but must provide clear mechanisms for consumers to opt out of the sale or sharing of their data. Also unlike the GDPR, the CCPA does not bind all businesses and service providers, but only those who (1) do business in California (2) with Californian residents and (3) either (i) buy, sell, or share the personal information of at least 100,000 consumers or households, or (ii) had a gross annual revenue of at least US\$25 million, or (iii) generate at least 50% of their annual revenue from selling or sharing personal information. The CCPA’s enactment has spurred a wave of similar legislation across other U.S. states [53, 54, 88].

Prior Empirical Research on CCPA. Empirical work on the CCPA has examined opt-out mechanisms, usability, and policy text, each through a different lens. Studies of opt-out deployment found that many websites bury or geofence opt-out links [109], that only ~2% of 500,000 sites displayed the required “Do Not Sell” link [116], and that dark patterns in opt-out interfaces suppress user completion rates [78, 87]. More recent work documents that these issues persist under the CPRA: Tran et al. [110] systematically exercised the full opt-out process on 330 websites, finding that nearly 30% of requests fail [102]. At the policy-text level, studies have found ambiguity in CCPA-mandated disclosures and internal contradictions in overlapping privacy policies [32, 120]. Broader surveys and empirical work further document gaps in tracker disclosure and the difficulty of privacy-compliant implementation [12, 14, 64, 71].

Our work differs from prior studies in two respects. First, prior CCPA studies generally examine a single compliance dimension: the deployment and readability of “Do Not Sell” links [109, 116], dark patterns in the opt-out process [87, 110], or policy text [32]. In contrast, PrivAudit is the first to jointly audit policy disclosures and front-end cookie behavior at the website level, using potential mismatches between them as an audit signal. Examples include a site whose policy states that it does not sell personal data but sets third-party Targeting cookies on page load, or one that claims to honor GPC but exhibits no corresponding reduction in tracking when the signal is sent (§4.3). Second, although we reuse the corpus of Tran et al. [109] for comparability of the CCPA-Subject versus CCPA-Not-Subject websites, they audit only the *opt-out mechanism*—whether opt-out links are deployed, readable, and free of dark patterns—whereas we evaluate the *content* of policy disclosures against specific CCPA provisions and measure the *cookie-writing behavior* those policies describe.

A parallel line of work examines whether opt-out signals are honored downstream in the advertising ecosystem. Aziz et al. [10]

audited the IAB CCPA Compliance Framework and found that 90% of advertising and analytics domains never read the opt-out API. Liu et al. [75] complemented this by auditing advertisers’ real-time bidding behavior, finding that several major ad platforms continue collecting data after opt-out. Technical audits of GPC specifically have found that fewer than half of websites honor the signal across all implemented consent strings [61], that users understand and would enable GPC but backend compliance remains low [125], and that GPC has minimal effect on app-level ad tracking on Android [124]. Bryson et al. [18] further documented gaps in how platforms communicate data practices through ad transparency systems. These studies assess *CCPA compliance* by inspecting consent strings such as the US Privacy String and GPP String to determine whether websites update their opt-out status when privacy signals are sent [61, 123, 125]. However, correct propagation of opt-out signals does not guarantee that data collection actually stops. For example, third-party cookies can persist even after consent rejection [96], and enforcement actions have penalized businesses whose tracking continued despite opt-out signals and consent interfaces [29]. Our work complements this body of work by measuring a different layer: the *cookies and tracking scripts* that websites deploy. By testing six privacy configurations—including GPC, Do Not Track (DNT), third-party cookie blocking, ad blocking, and consent banner interaction—and comparing behavior across CCPA-Subject and CCPA-Not-Subject websites, PrivAudit captures whether front-end data collection practices change in response to a variety of user privacy choices.

Advances in Privacy Policy Analysis. Recent work has leveraged LLMs and natural language processing (NLP) to automate privacy policy analysis, including summarizing and classifying policies [51, 100, 108, 119], detecting ambiguity and contradictions [40, 57], evaluating clauses against statutory requirements [2, 81, 98, 121], and tracking how disclosures evolved longitudinally in response to GDPR and CCPA [65, 117]. Other work has automated policy collection and analysis at scale [67] and found that automated policy generators systematically fail to comply with major privacy laws [92]. Most relevant to our work are systems that compare policy claims against observed behavior. PoliCheck [6] links Android app policies to actual data flows, OVRSeen [111] audits VR network traffic against policy statements, PoliGraph [36] maps policy text to specific data practices via knowledge graphs, and DiffAudit [48] uses GPT-4 to compare data flows across user age groups under COPPA and CCPA. Other tools link policy text to app or extension behavior [3, 5, 19, 33, 35, 73, 91]. Our work differs from these systems in two ways: we use a *CCPA-specific* rubric mapped to opt-out-based statutory provisions rather than generic privacy practice ontologies, and jointly analyze policy disclosures with observed cookie behavior to surface audit-relevant signals.

Auditing Cookie-Based Tracking. Cookie-based tracking is part of a broader ecosystem that includes fingerprinting, evercookies, cookie synchronization, and widespread identifier sharing by a small set of dominant entities [1, 20, 45, 46, 93, 99]. Recent work shows persistent gaps between consent and tracking: popular sites may offer reject buttons yet ignore rejection [16], declared consent signals often diverge from actual tracking under the IAB Europe TCF [103], and tracking can persist through respawning, cloaked

¹<https://github.com/r-andlab/PrivAudit>

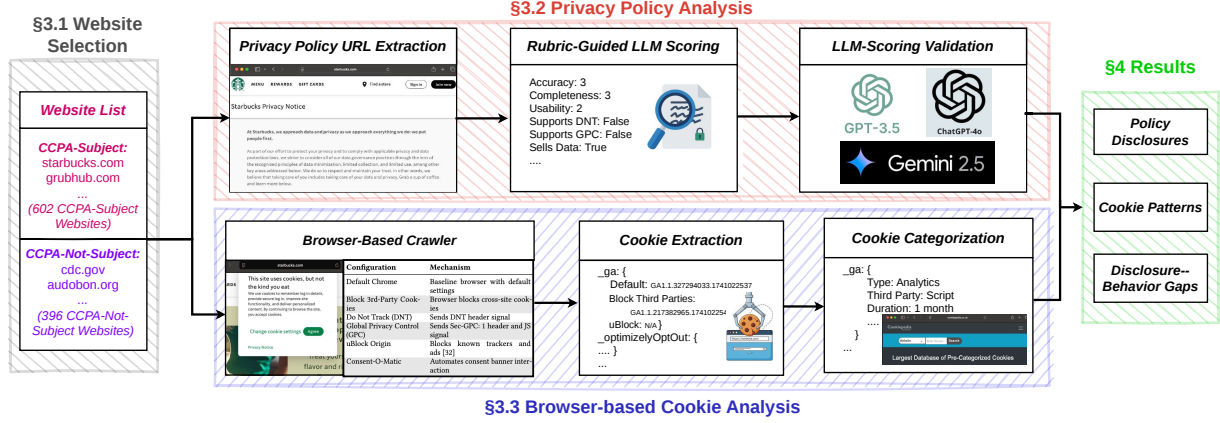


Figure 1: PrivAudit workflow. PrivAudit applies two parallel pipelines on websites: one that uses rubric-guided LLM scoring to analyze privacy policies, and another that uses a crawler to collect and analyze cookies.

domains, and incorrect consent data [49, 50, 123]. Finally, third-party tracking can expose sensitive health information beyond what traditional cookie analyses capture [122].

Parallel user studies consistently find that consent interface design shapes tracking outcomes more than user intent. Dark patterns in cookie banners increase acceptance rates and make rejecting tracking difficult [76, 85, 86], while deployed banners systematically guide users toward acceptance [15, 37, 60, 77, 107, 115]. Subsequent work has identified additional barriers: standard cookie category labels are poorly understood by users [70], automated consent tools vary in effectiveness [39], dark patterns may give rise to legal redress [58], and consent mechanisms are increasingly tied to payment alternatives [17, 59, 80, 96, 106].

While prior work on cookies largely focuses on GDPR’s opt-in regime, cookie-setting behavior under opt-out models like the CCPA remains underexplored. Our work complements this literature by auditing front-end, user-facing privacy behavior: we measure initial cookie writes under six privacy configurations and jointly analyze these measurements with CCPA-grounded policy disclosures.

3 Methods

PrivAudit Overview. We present PrivAudit, an automated, dual-pronged auditing framework that integrates structured LLM-based privacy policy analysis with large-scale detection of cookie writes. Figure 1 illustrates an overview of the framework. PrivAudit takes as input a curated set of website URLs, selected to include both CCPA-Subject and CCPA-Not-Subject websites (§3.1). For each site, PrivAudit executes two parallel workflows on website homepages. The first workflow, *Privacy Policy Analysis*, systematically locates and extracts privacy policy links, and evaluates policies with multiple state-of-the-art LLMs, which score them based on a CCPA-guided rubric validated through expert legal review (§3.2). To ensure robustness, we validate LLM outputs through natural-language explanations, inter-model consistency checks, and manual verification. The second workflow, *Browser-based Cookie Analysis*, employs a browser-based crawler to visit each website under six privacy configurations and collect cookies (§3.3). Cookies are then

classified based on their function and source. Together, the two workflows provide a novel end-to-end view of both user-facing privacy disclosures and cookie setting practices in the CCPA context.

The design of PrivAudit addresses three key challenges in privacy analysis: (1) *Scalability*: traditional privacy audits require substantial manual effort to analyze policy text and site behavior. PrivAudit overcomes this through automated policy extraction, LLM-driven text analysis, and a fully automated crawling and cookie classification pipeline. (2) *Legal Foundation*: prior work has rarely linked empirical analysis with the explicit requirements of privacy law. PrivAudit bridges this gap by grounding its policy evaluation rubric directly in CCPA clauses and validation through expert legal review. (3) *Realistic User Simulation*: end-users employ diverse privacy strategies (e.g., browser settings, privacy headers, consent-management extensions), making it difficult to replicate real-world browsing conditions. PrivAudit tackles this by using six distinct privacy configurations that reflect common user privacy practices, including opt-out signals [47, 97]. To ensure that our measurements reflect CCPA-relevant behaviors, all measurements were collected in a client located in California in mid-2025.

3.1 Website Selection

The first step in our analysis is to identify websites relevant to our study. While measurement studies often rely on popularity-based lists, selecting domains for CCPA-focused analysis is more nuanced since the statute only applies to for-profit entities meeting specific thresholds of annual revenue and data collection scope (See §2). However, collecting such metadata about websites is challenging at scale, as most of them do not publicly disclose corporate revenues and user demographics.

To address this challenge and ensure comparability with previous work, we base our selection on the curated data set of Tran et al. [109], which provides a domain classification using structured business intelligence sources and publicly available data. We contacted the authors and obtained the dataset comprising 1,017 domains, and filtered out inactive or defunct sites, yielding a final

sample of 1,002 active websites, which we refer to as the *Known-Subjectivity list* (see Appendix D for business classification). We re-verified and re-labeled each website’s CCPA applicability from two signals used in this prior work [109]—company annual revenue and organizational type. We obtain revenue from the Apollo business-intelligence database [7]² and organizational type from public records (SEC EDGAR [114], Wikidata [118], and GLEIF [55]). We exclude 4 websites whose subjectivity we cannot confidently establish, leaving 998 websites for analysis. In total, we compare 602 for-profit websites subject to the CCPA (CCPA-Subject) against a group of 396 websites that are not subject (CCPA-Not-Subject). However, only 915 set any cookies at all upon homepage visits, so we consider only these websites for our cookies analysis.

To assess whether PrivAudit scales beyond corpora with pre-established subjectivity, we additionally construct the *Popular-Website list*: a second, unlabeled set of 1,000 websites drawn directly from the Tranco ranking of popular websites [94]. We keep one base domain per site (e.g. `example.com`) under generic or U.S.-oriented TLDs—those most likely to be U.S. consumer sites relevant to the CCPA—require an active homepage, and sample 250 sites per Tranco rank band (top-1k, 1k–10k, 10k–100k, 100k–1M), excluding every domain in the Known-Subjectivity list. Unlike the Known-Subjectivity list, we do not determine whether each of these sites is subject to the CCPA; we run the full PrivAudit pipeline on them both to test scalability and to study sites that publicly claim CCPA compliance regardless of their formal subjectivity. The full protocol and results are provided in Appendix E.

3.2 Privacy Policy Analysis

A central obligation under the California Consumer Privacy Act (CCPA) is that businesses publicly disclose consumer rights such as access, deletion, and opt-out through a clear and accessible privacy policy (California Civil Code §1798.130(a)(5)(A)). In this section, we describe PrivAudit’s privacy policy auditing workflow.

3.2.1 Privacy Policy URL Extraction. To analyze websites’ alignment of privacy claims with the CCPA, it is necessary for PrivAudit to reliably locate and extract their privacy policies. However, automatically locating privacy policies across a diverse set of websites presents a unique challenge, since privacy policies are not consistently labeled or linked. Websites may use generic links such as “Terms”, some of which may lead to irrelevant legal pages. Moreover, websites frequently offer multiple policy-related links, including region-specific disclosures, complicating identification.

To resolve these challenges, we built a two-tiered automated extraction pipeline for PrivAudit using headless browsing with Selenium and XPath-based DOM querying. The pipeline first attempts a targeted XPath extraction based on a carefully curated set of high-precision privacy-related keywords that we search for in the website’s homepage. To identify these keywords, we randomly sampled 50 websites from our study corpus of 998 domains and manually visited each to identify the privacy policy URL. Using

this set of labeled websites, we identified a set of two keywords—“Privacy Policy”, “Your Privacy Rights”—that were highly successful in identifying privacy policy pages through anchor (<a>) tags without any false positives. We apply the two high-precision keywords to our full set of 998 websites. If no matching anchor (<a>) elements are found using this targeted approach, the pipeline proceeds to a fallback stage that scans all anchor elements for either the word “privacy” in their visible text or the substring “privacy” in their URL. This fallback ensures coverage for websites with non-standard labeling practices. Using this automated two-tiered pipeline, we were notably able to obtain privacy policy-related pages for all 998 websites in our dataset, resulting in a total of 933 combined privacy policies³, which we use for our analysis. We validated the accuracy of our method by manually visiting all privacy- and terms-related links on a separate, disjoint random sample of 50 websites from the same corpus. We only find one website (`www.underarmour.com`) with an extra page not identified with our automated pipeline, but which was focused towards international clients (not CCPA-related), which are not the focus of our study.

3.2.2 LLM-Based Analysis of Privacy Policies. To audit whether websites offer actionable rights under the CCPA, PrivAudit needs to verify whether privacy policies clearly, accurately, and completely articulate user rights, while ensuring that this evaluation is robust enough to capture nuanced legal language. However, privacy policies are inherently challenging to parse, even for experts, due to their unstructured format, varied writing styles, and legalistic ambiguity [79]. While prior NLP systems have successfully automated policy classification and practice extraction, they typically target generic privacy ontologies or specific platforms (mobile apps, VR) [6, 36]. Applying these approaches to CCPA-specific compliance evaluation requires a rubric grounded in the statute’s particular legal requirements.

To address these challenges, we design a structured, rubric-guided evaluation pipeline for PrivAudit that leverages LLMs while grounding assessments in the legal provisions of the CCPA. This approach enables PrivAudit to use LLMs as transparent, explainable evaluators rather than opaque black-box classifiers. We begin by parsing each privacy policy into semantically distinct passages. First, we use XPath-based extraction to segment the HTML DOM into structural elements (headings, paragraphs, and list items). For policies lacking clear structural markup, we apply MiniLM sentence embeddings to cluster semantically related text spans into coherent passages. These passages are then fed into a structured LLM prompt (see Appendix O for the full prompt) that elicits a multi-dimensional assessment along with natural-language explanations for each assessment. PrivAudit’s prompt asks the LLM model to evaluate six key compliance dimensions: (1) *Completeness* of rights disclosure (score between 0–3), which evaluates coverage of core CCPA rights including right to access, delete, and opt-out; (2) *Usability* of access mechanisms (score between 0–3), which assesses the presence of actionable mechanisms like contact forms or links; (3) *Accuracy* of provisions and terminology (score between 0–3), which checks for correct use of statutory terms and definitions; (4) *Disclosures* of key privacy practices (boolean), which provides

²Tran et al. [109] draw these signals from PitchBook and ZoomInfo, which are sold only through direct business-to-business sales contracts on an annual basis, which were not available to us at the time of writing. We instead subscribed to Apollo, a comparable business-intelligence provider offering self-serve access to individual researchers, and validated its revenue figures against SEC EDGAR filings for the public companies in our sample, finding complete agreement on the statute’s \$25M gross-revenue threshold.

³We note that this number is less than 998 since many domains share privacy policies—for example, `google.com` and `youtube.com`.

binary indicators (True/False) for the presence of disclosure of data collection, sharing, purpose, retention period, and user rights (access, delete, opt out); (5) *Privacy Claims* which provides ternary indicators (True/False/Unspecified) for privacy claims including the honoring of Do Not Track (DNT) and Global Privacy Control (GPC) signals, cookie setting and consent behavior, and the selling and sharing of data with third parties; and (6) *Mentions* of privacy laws and practices, boolean indicators (True/False) of references to online (cookies, SDKs, analytics) and offline data collection methods, and the CCPA law itself.

We map each of the above compliance dimensions explicitly to corresponding CCPA/CPRA statutes (Appendix N) and validate them through expert review: an external privacy-law expert at a public-sector regulatory organization—holding a Juris Doctor with over 15 years of experience in California privacy regulation—reviewed each provision-to-dimension mapping, confirmed its correctness, and suggested minor refinements that we incorporated (see Appendix N for details). For instance, the completeness score and disclosures of key privacy practices align with requirements under §1798.100(a), §1798.105, §1798.110, §1798.120, and §1798.121, ensuring that policies enumerate consumer rights such as access, deletion, and opt-out of sale or sharing. The usability score and opt-out disclosures correspond to §1798.130(a)(1)(A), which mandates that businesses provide multiple accessible methods for consumers to exercise these rights (e.g., toll-free number, webform). Finally, the accuracy score, privacy claims and mentions are based on §1798.140 (definitions) and §1798.100(b), requiring the use of correct terminology to describe rights and obligations. Along with each evaluation, we ask the LLM to include a natural-language rationale with direct references to the policy text.

3.2.3 LLM Implementation and Validation. Deploying LLMs for privacy policy assessments introduces a critical challenge: ensuring the reliability and interpretability of model outputs. Unlike deterministic rule-based systems, LLMs may generate variable responses due to differences in training data, architecture, and sampling behavior. Traditional human-annotated ground truth datasets for privacy policies are scarce, making direct validation difficult.

To resolve this challenge, we first conduct a systematic inter-model agreement analysis across three leading foundation models: GPT-3.5, GPT-4o, and Gemini 2.5. Our objective is to empirically assess whether different LLMs, when presented with the same structured prompt and policy passages, would yield consistent semantic interpretations. We treated this agreement as a practical proxy for output stability, a concept increasingly recognized in LLM evaluation literature [98, 108]. We randomly select 200 policies from our corpus and obtain independent responses from each LLM using the six-dimensional scoring schema detailed in Section 3.2.2. For categories with boolean outputs, such as *Mentions* and *Disclosures*, we computed Fleiss’ κ to measure inter-rater consistency across the models. The analysis yielded $\kappa = 0.74$, which falls in the “substantial agreement” range (0.61–0.80) on the widely used Landis–Koch scale [72]. This level of agreement is comparable to typical inter-annotator scores reported in NLP classification tasks [9], and suggests that our structured prompt framework induces consistent cross-model interpretations. For categories scored on a 0–3 scale

(e.g. *Completeness*), we calculate pairwise Spearman rank correlations between model pairs. Correlation coefficients ranged from $\rho = 0.69$ to $\rho = 0.83$, indicating moderate to strong alignment in scoring patterns across the different LLMs.

To further strengthen output reliability and mitigate hallucination risks, we next implement a multi-tiered validation protocol informed by the cross-model validation and manual analysis. First, all LLM outputs are required to conform to a strict JSON schema, with malformed responses automatically rejected and re-queried using reinforced prompts. Second, we manually reviewed a stratified sample of 60 outputs per model, noting hallucination rates between 2–5% depending on policy length and model type. Common hallucinations included fabricated opt-out mechanisms or unsupported legal claims. These were addressed by iterative prompt conditioning—for example, instructing models to reply with “Not mentioned” when uncertain—and post-processing checks such as comparing explanations with scores and policy text: any claim not corroborated by the policy text or contradicted by the model’s own explanation is discarded. This protocol helps avoid both false positives and negatives. Among the three LLMs, GPT-4o provided the most consistent legal term recognition and accurate explanations, so we report results using GPT-4o with manual verification. Importantly, this selection is based on output *quality*, namely closer agreement with our manual review (a random sample of 100 policies we hand-labeled as ground truth, on which GPT-4o’s scores agreed with our labels 97% of the time, versus 92% for Gemini and 91% for GPT-3.5) and more reliable recognition of legal terminology, and was fixed before our substantive analysis rather than chosen to fit any particular result. Moreover, the substantial cross-model agreement reported above (Fleiss $\kappa = 0.74$; pairwise Spearman $\rho = 0.69$ –0.83, measured on the 200-policy sample) indicates that the three models extract largely the same signals from each policy, so the differences we report are unlikely to be specific to any single model.

To test whether residual LLM errors could affect our findings, we ran a Monte Carlo sensitivity analysis with 1,000 iterations, randomly flipping 5% of boolean labels and perturbing 5% of ordinal rubric scores by ± 1 , matching the upper bound of our observed hallucination rate. Nine of ten originally significant results remained significant ($p < 0.05$) in $\geq 99.8\%$ of iterations, indicating that the Subject–Not-Subject differences we report are robust to measured LLM error and stable enough for scalable auditing in practice. The only exception is the data-selling disclosure rate (33.0% vs. 23.2%, $V=0.10$), whose smaller effect size made it sensitive to label noise; we flag this in our results (§4.1).

3.3 Browser-based Cookie Analysis

We next instrument PrivAudit with a browser-based crawler to audit website cookie writes, one of the most prominent methods for tracking users online [46]. Although the CCPA does not explicitly regulate cookie writes themselves, cookies serve as the primary technical mechanism through which third-party data collection is initiated, which *can* constitute a “sale” or “sharing” of personal information under the statute. In the landmark *People v. Sephora* enforcement action (2022), the California Attorney General imposed a \$1.2 million penalty for, among other violations, failing to disclose

data sales facilitated by third-party cookies and failing to honor GPC opt-out signals [21]. Subsequent enforcement actions have similarly targeted businesses whose cookie and opt-out practices fell short of statutory requirements [22, 29]. These precedents motivate our measurements of cookie deployment as a *scalable and externally observable auditing signal* of data collection practices.

3.3.1 Automated Browsing and Cookie Extraction. We design an automated crawling infrastructure using the Chrome browser that systematically simulates real-world user visits across a diverse set of privacy configurations. While previous studies have explored website crawling and cookie analysis in detail [15, 37, 46, 77], our study highlights unique challenges in simulating diverse browsing profiles and extracting structured, meaningful cookie data. In practice, users often deploy privacy-enhancing tools such as ad blockers, consent managers, or privacy headers that interact with websites and influence tracking outcomes. To simulate these behaviors, we adopt six browser configurations deliberately chosen to represent a spectrum of privacy-preserving behaviors, as shown in Figure 1. In the first configuration, we use the default Chrome browser with no privacy enhancements, which provides a baseline. In our second configuration, we instrument Chrome to block third-party cookies, a common user tactic to curb cross-site tracking. The third configuration involves setting the Do Not Track (DNT) header which represents a standardized, albeit often ignored [74, 101], signal of a user’s online tracking preferences. The fourth configuration enables Global Privacy Control (GPC), a more recent privacy signal that communicates user opt-out preferences through both the Sec-GPC: 1 HTTP header and the navigator.globalPrivacyControl JavaScript API [82]. Unlike DNT, GPC carries legal weight under the CCPA, requiring subject businesses to honor the signal as a valid consumer request to opt out of data sale and sharing [89]. This distinction makes GPC particularly relevant for our study. Finally, we incorporate two commonly-used browser extensions: uBlock Origin powered by EasyList [44] for blocking known trackers and advertisements, and Consent-O-Matic, which automates the rejection of cookie consent banners [84].

To perform extensive crawling under the different privacy configurations, we use Puppeteer, a Node.js-based browser automation framework. We execute each browsing session for each privacy setting within a clean, headless Chromium instance to ensure strict session isolation. We set page load timeouts to 90 seconds or until the Document Object Model (DOM) completes loading, after which we systematically extract cookies using Puppeteer’s `page.cookies()` API. We design a structured logging system that captures both the raw cookie data and its contextual metadata within each browsing session, including the cookie name, domain, value, expiration timestamp, and setting script. We also annotate websites based on the presence of cookie consent banners, an important user-facing privacy signal made mandatory by laws like GDPR [112]. On each website homepage, we use JavaScript to automatically detect banners or consent management platforms via common identifiers and classes (e.g., “consent”, “onetrust-banner-sdk”). For sites with no automatic matches, we manually review the homepage to ensure all consent banners are identified. *Across our dataset, only 239 (27%) of websites displayed a consent banner.* This trend persisted among regulated entities, with just 183 (33.2%) of CCPA-Subject sites showing

a banner compared to 56 (15.4%) of CCPA-Not-Subject sites. Using Consent-O-Matic, we capture cookies under different consent scenarios when banners are present. An initial snapshot is captured immediately upon page load, representing the baseline data collection. If a consent banner is detected, we simulate user actions by both accepting and rejecting non-essential cookies using Consent-O-Matic, and capture follow-up snapshots of the cookie state following this interaction.

Internal-Page Crawl. To assess homepage representativeness, we additionally crawl up to five internal pages per site under all six configurations using the same analysis pipeline. Appendix K provides details and results.

3.3.2 Cookie Functionality Classification. Accurate classification of cookies and understanding their purpose (e.g. whether they are targeting or functional) is a critical but challenging step in analyzing tracking. Many cookies employ hashed or dynamic names and values that obscure their function. Trackers also often operate under aliased domains or content delivery networks, and individual public classification databases are often incomplete [4, 41, 62, 69, 83, 93]. To address these challenges, we synthesize datasets from multiple sources to maximize categorization coverage. Specifically, we obtain and parse public cookie categorization datasets from Cookiepedia [34], the Open Cookie Database [90], and Cookie Cutter DB [66]. For cookies that remain unclassified after name-based matching based on these datasets, we employ domain-based categorization by matching the setting script’s origin domain against known tracker databases, specifically DuckDuckGo Tracker Radar (708 categorized tracking domains) [43] and Disconnect tracking protection lists (2,322 services across advertising, analytics, social, and content categories) [42]. We curate the various categories from these databases into four unique categories for our analysis: (1) *Strictly Necessary* cookies (e.g. `sessionID`, which maintains login sessions), (2) *Functional* cookies (e.g. `__cf_bm`, which Cloudflare uses to distinguish humans from bots), (3) *Performance* cookies (e.g. `nmstat`, which records site analytics), and (4) *Targeting* cookies (e.g. `FCNEC`, which is linked to Facebook and Google services for delivering targeted marketing). Any cookies for which we cannot find data across all sources are flagged as “Unknown.” Using our multi-source approach, PrivAudit successfully categorizes **70.6% of all cookies** (13,502 of 19,119), leaving only 29.4% (5,617 cookies) as “Unknown.” This represents a substantial improvement compared to prior academic work [20, 66, 83]. We were able to categorize at least one cookie for 877 (95.8%) websites and at least three-quarters of cookies for 658 (72%) websites, enabling a representative view of website behavior.

Validating Cookie Categorization. To validate our categorization, we audited the 200 most prevalent cookies against their documented purpose in published vendor and cookie-reference sources (e.g. `cookie.is` and vendor ad-tech documentation), supplemented by manual review of the most prevalent. We could establish a confident reference for 171 of them (the other 29 were too ambiguous to label). On the *Targeting-vs-non-Targeting* distinction that our findings rest on, our labels matched this reference for 94% of the 171 (93% weighted by prevalence), with 3 false positives and 7 false negatives. Since the errors are mostly false negatives—advertising

cookies (e.g. `permutive-id`, `__eoi`) we conservatively mark non-Targeting, rather than consent cookies (e.g. `_tracking_consent`) wrongly flagged—our categorization errs toward under-counting, so the tracking rates we report are a conservative lower bound.

3.3.3 Third-Party Cookie Classification. We adopt a dual classification framework to distinguish first-party and third-party cookie in the modern web environment [11].

Domain-Based Classification. Using the conventional definition, we classify a cookie as *third-party* if its domain attribute does not match the eTLD+1 of the website. This classification reflects the cookie’s scope of access and Same-Origin Policy restrictions, but does not reveal *who* initiated the cookie write. We find only a small number of third-party cookies (4.3%) under this definition.

Script-Based Attribution. To identify the true controller of cookie writing behavior, we adopt a *script attribution* classification that determines which origin’s code executed the cookie write, regardless of the cookie’s domain. Our approach builds on established call-stack interception techniques used for cookie attribution in prior work [11, 31, 46]; we apply these techniques across our six configurations to measure how third-party script behavior changes in response to user privacy practices. Specifically, we instrument two interception methods: first, we redefine the native `document.cookie` setter to capture every JavaScript-initiated cookie write along with its call stack, including the *source URL* of each function in the stack; second, we monitor all HTTP responses for Set-Cookie headers to capture server-side cookies, including those marked `HttpOnly`.

A cookie is then classified as *third-party by attribution* if the source URL of the script that initiated the write belongs to a different eTLD+1 than the visited website, even when the cookie itself carries a first-party domain. For example, if a script loaded from `google-analytics.com` writes a cookie scoped to `.example.com` via `document.cookie`, our call-stack instrumentation technique records `google-analytics.com` as the initiating origin, and we classify this cookie as third-party because the external script controls the cookie lifecycle. This distinction is critical because third-party scripts routinely set nominally first-party cookies to evade browser restrictions on third-party cookie access while maintaining cross-site tracking capabilities [11, 31, 38, 83]. We note that our method attributes cookies based on the *URL from which the browser loaded the script*; if a website self-hosts or proxies a third-party script through its own domain (e.g. via CNAME cloaking [41]), the script would appear as first-party in our classification. This is a known limitation shared with prior call-stack-based attribution approaches [31, 83], and means our third-party results represent a conservative lower bound. An independent re-parse of the raw call stacks reproduced our attribution for 99.97% (7,358/7,360) of script-set cookies with parseable stacks.

3.4 Statistical Analysis

We evaluate the significance of differences between CCPA-Subject and CCPA-Not-Subject websites using non-parametric and categorical tests. For ordinal and count-based metrics such as rubric scores (rated 0–3) and cookie counts, we use the Mann-Whitney *U* test, which does not assume normality and fits our distributions skewed towards higher values for CCPA-Subject websites.

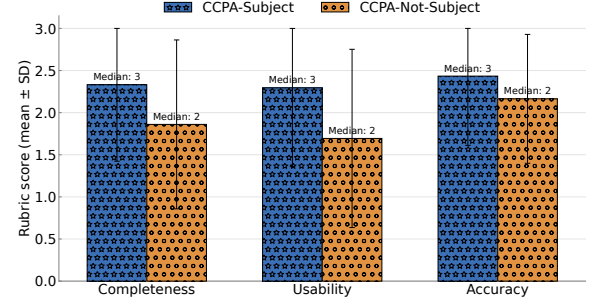


Figure 2: Rubric scores (Completeness, Usability, Accuracy) of privacy policies by CCPA subjectivity. Bars show group means with error bars (standard deviation).

For binary and categorical variables, including disclosures, behavioral claims, and third-party script attribution, we use Pearson’s χ^2 test of independence, and apply Fisher’s exact test when expected counts are below five. We report two-tailed *p*-values and set the significance level to $\alpha = 0.05$. For interpretability, we include effect sizes: the rank-biserial correlation (*r*) for Mann-Whitney tests and Cramér’s *V* for χ^2 tests. Values of 0.1, 0.3, and 0.5 correspond to small, medium, and large effects respectively.

Because we run many comparisons, we treat all 25 tests as a single family and report multiple-testing-adjusted *p*-values two ways: the Benjamini-Hochberg procedure [13], controlling the false-discovery rate (FDR), and—following prior CCPA measurement work [87]—the stricter Holm-Bonferroni step-down procedure [63], controlling the family-wise error rate (FWER). Holm-Bonferroni is a uniformly more powerful form of the classic Bonferroni correction, and its family-wise error control holds under arbitrary dependence among the tests [63]; we base our significance decisions on the more conservative Holm-adjusted *p*-values, with Benjamini-Hochberg as a complementary view. Appendix M reports the raw and adjusted *p*-values for all 25 tests. Under the stricter Holm criterion, our main takeaways in §4 remain unchanged. To confirm these disclosure differences reflect CCPA applicability rather than firm size or ad-revenue reliance, we additionally adjust for both via per-disclosure logistic regressions and a size-matched comparison against large CCPA-exempt organizations with full specifications and results in §4.1 and Appendix L.

4 Results

We present PrivAudit’s findings in three parts: privacy policy auditing (§4.1), cookie-write auditing (§4.2), and a joint policy-behavior analysis that links disclosures to observed tracking (§4.3). We additionally validate that these signals generalize to an unlabeled 1,000-site corpus in a scaling case study (Appendix E).

4.1 Privacy Policy Findings

We analyze the six key compliance dimensions across CCPA-Subject (*N* = 567) and CCPA-Not-Subject (*N* = 366) policies in the 933 privacy policies identified by PrivAudit. First, we observe that CCPA-Subject privacy policies are significantly more complete (Mann-Whitney *U* test, $p < 0.001$, $r = 0.27$), usable ($p < 0.001$, $r = 0.31$),

Table 1: Disclosure coverage, behavioral claims, and privacy-practice mentions in privacy policies. “True” percentages are shown for disclosures and mentions; behavioral claims report True (T), False (F), and Unspecified (U) rates.

Metric / Claim	Subject	Not-Subject	Example Policy Excerpt (True cases)
Disclosure Coverage	<i>n</i> = 567	<i>n</i> = 366	
Data Collection	85.9%	89.9%	"The information we collect [includes]...interactions, device information, [and] location information"
Data Sharing	86.4%	83.3%	"We may share your information with our service providers... advertisers...[and] affiliates"
Data Collection Opt Out	77.1%	57.1%	"[C]ontrol whether [this website] shares your personal information...by using the 'Data sharing...' option"
Purpose of Collection	87.3%	91.0%	"We use the information we collect to provide and operate [feature]...improve and personalize [feature]...foster safety and security...[and] measure and analyze"
Data Retention Period	64.6%	49.2%	"We keep different types of information for different periods...cookies up to 13 months..."
Right to Access	85.4%	68.3%	"You can access, correct, or modify the information...You can download a copy of your information"
Right to Delete	85.9%	69.4%	"If you follow the instructions... your account will be deactivated and your data will be queued for deletion."
Mentions	<i>n</i> = 567	<i>n</i> = 366	
Cookies	84.1%	89.1%	"We use cookies, pixels and other Tracking Technologies to collect information about you"
CCPA	67.3%	43.1%	"California residents can submit requests to opt out of the sale of personal information under the...(CCPA). "
Online Data Collection	92.1%	94.5%	"We may send...cookies...We may also use other similar technologies such as tracking pixels, tags..."
Offline Data Collection	35.8%	10.7%	"Personal information may be collected ...when you visit our stores... or deal with customer service"
Behavioral Claims	<i>n</i> = 567	<i>n</i> = 366	
Deletes Cookie After Rejecting Consent	T: 0.2% F: 0.0% U: 99.8%	T: 0.3% F: 0.0% U: 99.7%	"[C]lick here to...control, disable, or delete [cookies]."
Sets Cookies After Rejecting Consent	T: 0.0% F: 0.2% U: 99.8%	T: 0.0% F: 0.3% U: 99.7%	No true cases.
Sets Cookies Before Consent	T: 0.7% F: 1.4% U: 97.9%	T: 1.4% F: 3.0% U: 95.6%	"If you continue using [website] we will assume that you are happy to receive cookies."
Tracking Only After Consent	T: 1.2% F: 0.4% U: 98.4%	T: 1.6% F: 0.0% U: 98.4%	"By default, you are opted out of all cookie categories except strictly necessary cookies."
Sells Data	T: 33.0% F: 36.0% U: 31.0%	T: 23.2% F: 42.1% U: 34.7%	"We may disclose certain personal information in exchange for services, insights, or other valuable consideration."
Shares Data with Third Parties	T: 82.7% F: 0.2% U: 17.1%	T: 79.8% F: 4.4% U: 15.8%	"We may share your personal information with...service providers"
Honors GPC	T: 28.7% F: 0.2% U: 71.1%	T: 13.1% F: 0.8% U: 86.1%	"You may use the Global Privacy Control (GPC)...If GitHub detects the GPC signal from your device, GitHub will not share your data."
Honors DNT	T: 2.1% F: 33.5% U: 64.4%	T: 1.9% F: 27.6% U: 70.5%	"If your browser sends a Do Not Track (DNT) signal, GitHub will not set non-essential cookies and will not load third party resources"

and accurate ($p < 0.001$, $r = 0.25$) than CCPA-Not-Subject policies, as shown in Figure 2. The median score for CCPA-Subject policies is 3 across all three dimensions, compared to 2 for CCPA-Not-Subject policies, indicating that CCPA-subject websites tend to provide more detailed, actionable, and legally precise disclosures. PrivAudit’s LLM-audit noted specific examples of this: [Completeness] “The policy clearly lists consumer rights under CCPA, including access, deletion, and opt-out of sale/share, with detailed instructions on how to exercise these rights.”, [Usability] “The policy provides multiple clear methods to exercise rights, including web links and a phone number, with detailed guidance on verification and timelines.”, and [Accuracy] “The policy uses correct legal terminology and aligns with CCPA/CPRA language, including references to GPC and opt-out rights”. In contrast, CCPA-Not-Subject policies scored lower, especially in usability and completeness. For example, “The policy mentions opt-out options for targeted advertising and data removal but lacks detailed instructions on exercising rights like access or deletion.” We noted that ~31% of CCPA-Not-Subject policies missed details regarding specific CCPA rights such as the right to access and delete data. Over 40% of CCPA-Not-Subject policies lacked detailed opt-out instructions, and these policies generally scored lower on usability.

While we observe CCPA-subject sites exhibiting better disclosure practices, some of this difference may stem from these sites being larger and deriving more revenue from data sharing. Controlling

for company revenue and third-party tracking intensity, however, CCPA subjectivity remains a strong predictor of the opt-out, access, and deletion disclosures (all $p < 0.001$), and the gap persists among large organizations above the statute’s \$25M threshold (opt-out 77% vs. 46% for large but exempt nonprofits and government agencies); we detail this in Appendix L. The gap thus reflects CCPA *applicability* rather than firm size or ad-revenue reliance alone, though as an observational comparison it cannot establish strict causation. Consistent with this, 67.3% of CCPA-Subject privacy policies mention the CCPA (Table 1), often with sections addressing its specific clauses, and 43.1% of CCPA-Not-Subject sites also mention it—a notable spillover effect—suggesting the growth of transparency is attributable at least in part to the CCPA, in line with prior work [109] showing more opt-out links when sites are accessed from California.

Takeaway 1. CCPA-Subject websites provide significantly stronger privacy disclosures than CCPA-Not-Subject websites across completeness, usability, and accuracy.

Table 1 shows that many core disclosures are common across both groups, but CCPA-Subject policies are stronger on CCPA-specific rights. More than 85% of both CCPA-Subject and CCPA-Not-Subject policies disclose data collection and sharing practices. However, the specificity of these statements varies substantially,

with some specifying exactly what data is collected and shared (e.g. “The information we collect [includes]...interactions, device information, [and] location information”) and others providing generic information (e.g. “We collect several different types of information for various purposes to provide and improve our Service to you”). Importantly, we find that CCPA-Subject policies are significantly more likely to disclose the right to access data (85.4% vs. 68.3%, χ^2 , $p < 0.001$, $V = 0.20$), the right to delete data (85.9% vs. 69.4%, $p < 0.001$, $V = 0.20$), and opt-out instructions (77.1% vs. 57.1%, $p < 0.001$, $V = 0.21$). We note that the percentage of CCPA-Subject websites offering opt-out information and links has slightly increased from previous studies such as Tran et al. [109], which reported only ~70% of CCPA-Subject websites included an opt-out link. CCPA-Subject websites are also significantly more likely to disclose data retention details than CCPA-Not-Subject websites (64.6% vs. 49.2%, χ^2 , $p < 0.001$, $V = 0.15$), though retention remains one of the weaker disclosure categories overall. Finally, online data collection practices are widely disclosed across both groups (93.2% overall), while offline data collection is much less commonly disclosed (26.0% overall).

When it comes to behavioral claims, we observe that both CCPA-Subject and CCPA-Not-Subject privacy policies do not specify detailed privacy-related practices (Table 1). For example, while most privacy policies (86.0%) mention cookies, less than 2% provide detailed information regarding cookies and consent behavior. We show later in §4.2 that both CCPA-Subject and CCPA-Not-Subject websites set a significant quantity of Targeting cookies despite user consent action, emphasizing the need to disclose such tracking behaviors. Similarly, more than 80% of both CCPA-Subject and CCPA-Not-Subject policies disclose sharing personal information with third parties, but explicit data-selling disclosures are less common (33.0% vs. 23.2%, χ^2 , $p = 0.002$, $V = 0.10$), though we note that this finding is sensitive to residual LLM labeling error (§3.2.3). Finally, a significantly larger portion (28.7%) of CCPA-Subject websites claim to honor the Global Privacy Control (GPC) signal compared to CCPA-Not-Subject websites (13.1%) (χ^2 , $p < 0.001$, $V = 0.18$). Interestingly, a few websites specifically mention not honoring this signal mandated by the CCPA, e.g. “We do not currently support the Do Not Track browser or any Global Opt Out/Global Privacy Control option”. Similarly, a significant portion of privacy policies (31.6%) in both cases specifically mention not honoring the DNT signal for storing cookies.

All of our main policy findings survive multiple-testing adjustment under the stricter Holm procedure (Holm-adjusted p from $<10^{-17}$ to 0.016, the latter for the data-selling disclosure; Appendix M). The comparisons that do not survive are ones we do not treat as findings, like broad disclosures that are common across both groups (e.g. general data collection, data sharing, and purpose of collection) and several secondary cookie tests (e.g. the overall third-party rate).

Takeaway 2. CCPA-Subject policies more often disclose access, deletion, and opt-out rights, while broad disclosures remain common across both groups. However, very few policies describe specific privacy practices in detail.

4.2 Cookies Analysis

We next analyze cookies across the cookie-setting 915 websites.

Data Collection by CCPA Subjectivity. Figure 3 shows that CCPA-Subject and CCPA-Not-Subject websites exhibit broadly similar cookie-writing behavior at first visit. In the Default configuration, both groups set a median of 3 Targeting cookies and 3 Performance cookies per website. Mann-Whitney tests show no significant difference in Targeting cookies between CCPA-Subject and CCPA-Not-Subject websites ($p = 0.56$, $r = 0.02$), revealing that both sets of websites set advertising and tracking cookies such as fbp (Meta/Facebook) and MUID (Microsoft/Bing Identifiers). Across cookie categories, all effect sizes are small ($r < 0.3$), suggesting that CCPA subjectivity is not strongly associated with reduced front-end cookie collection. Unfortunately, as noted in our privacy policy results (§4.1), detailed explanations of cookie use are also often absent from privacy policies, reducing overall transparency. We note that any observed differences in cookie deployment between CCPA-Subject and CCPA-Not-Subject could be influenced by business characteristics: CCPA-Subject websites tend to be larger commercial entities with more complex advertising relationships and greater reliance on third-party analytics.

Figure 3 and Table 2 also show the distribution of cookies set across the various privacy configurations excluding Consent-O-Matic, which we evaluate separately later. Privacy configurations reduce cookies to different degrees, but none eliminate tracking. Blocking third-party cookies reduces total cookies by 33.4%, while DNT reduces total cookies by 37.1% and Targeting cookies by 38.1%. This shows that the DNT signal is still respected by websites for setting cookies, contrary to findings from previous work [74].

The GPC signal demonstrates even stronger effectiveness, achieving an overall reduction of 51% in cookies, with Targeting cookies decreasing by 55.8% and Performance cookies by 33.4%. However, GPC’s effectiveness remains incomplete: even among CCPA-Subject websites, which are legally required under CCPA to honor GPC signals, about 45% of Targeting cookies are still set when GPC is enabled.

The most significant effect is observed in the uBlock configuration, where the EasyList blocklist [44] results in a decrease of 87% in Targeting cookies and 82% in Performance cookies. Third-party blocking lists are extremely successful in blocking non-functional cookies, preventing targeting but maintaining usability.

Takeaway 3. Cookie writes are similar across CCPA-Subject and CCPA-Not-Subject websites, and privacy signals such as GPC reduce but do not eliminate Targeting cookies.

Third-Party Cookies. Out of the 19,119 total cookies we analyze, we find that 58.5% of cookies (11,176) are purely first-party, whereas 41.5% (7,943) involve third-party writes, identified through either domain-based or script-based attribution (Table 2). The substantial presence of third-party cookies shows that third-parties still collect information about users from a large number of websites: 665 websites (72.8%) set at least one third-party cookie. In total, 40.4% (7,729 cookies) are discovered through our script attribution technique, compared to only 4.3% of cookies (823) discovered through domain-based classification, with an overlap of 3.2% of cookies. This discrepancy shows that most third-party cookie activity occurs

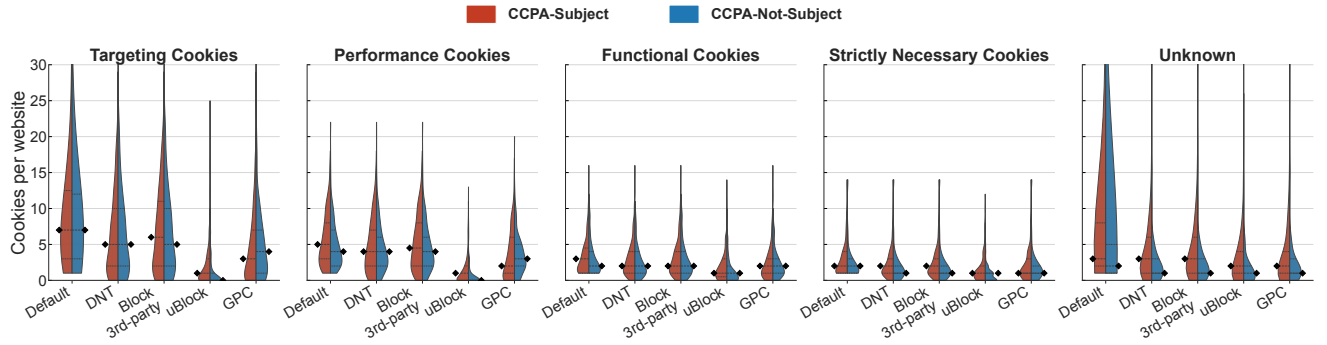


Figure 3: Cookie counts per website separated by CCPA subjectivity, cookie types, and browsing configurations.

Table 2: Third-party cookies by CCPA subjectivity. Default state shows cookie counts and third-party attribution percentages. Privacy configurations show percentage reduction in “total cookies (third-party cookies)”.

Cookie Type	N Script Domain		↓% Total (↓% 3P)				
	3P%	3P%	DNT	Block 3P	uBlock	GPC	
CCPA Subject (552 sites, 11,553 cookies)							
Targeting	3,670	51.0	4.1	34(8)	28(1)	83(87)	55(41)
Performance	2,038	66.5	6.1	14(9)	6(3)	79(83)	38(35)
Functional	1,431	41.6	5.6	10(9)	5(1)	47(71)	30(30)
Strictly Necessary	1,018	44.2	5.0	18(5)	14(7)	46(48)	27(18)
Unknown	3,396	10.3	2.7	57(27)	56(26)	68(73)	64(47)
Subtotal	11,553	40.0	4.3	33 (15)	28 (9)	70 (82)	49 (37)
CCPA Not-Subject (363 sites, 7,566 cookies)							
Targeting	2,722	45.0	5.0	44(23)	41(20)	93(93)	56(34)
Performance	1,426	78.3	5.8	10(2)	6(1)	87(88)	27(18)
Functional	663	53.5	6.9	12(8)	6(3)	57(66)	22(14)
Strictly Necessary	534	49.8	5.1	23(16)	21(14)	68(71)	24(20)
Unknown	2,221	6.6	1.6	79(64)	79(63)	86(86)	81(73)
Subtotal	7,566	41.1	4.3	43 (18)	41 (14)	85 (89)	53 (31)
Total (915 sites)	19,119	40.4	4.3	37 (17)	33 (11)	76 (85)	51 (34)

Table 3: Top 10 third-party scripts responsible for setting 58.4% of Targeting cookies in the first-party context.

Script Domain	Cookies	Sites	% Sample	Category
securepubads.g.doubleclick.net	294	144	15.7%	Advertising
www.googletagmanager.com	278	239	26.1%	Tag Mgmt.
bat.bing.com	273	132	14.4%	Ads/Analytics
connect.facebook.net	196	192	21.0%	Social/Ads
assets.adobedtm.com	181	59	6.4%	Tag Mgmt.
analytics.tiktok.com	131	62	6.8%	Social/Analytics
ak.sail-horizon.com	120	43	4.7%	Marketing Auto.
tags.tiqcdn.com	119	34	3.7%	Tag Mgmt.
sc-static.net	117	44	4.8%	Audience Meas.
cdn.attn.tv	100	18	2.0%	Marketing

through scripts that write cookies scoped to first-party domains, a pattern that can evade conventional browser-level third-party cookie blocking [11, 31, 38, 83].

Concentration Among Dominant Platforms. Third-party script-set Targeting cookies are *highly concentrated* among a small number of major technology platforms. Table 3 reveals that just 10 third-party scripts account for 58.4% of all script-set targeting cookies. Google’s advertising and tag-management infrastructure alone accounts for 576 Targeting cookies across 386 websites (42.1% of our sample), followed by major platforms such as Microsoft (275 cookies), Meta (197 cookies), and Adobe (181 cookies). This concentration suggests that a handful of intermediaries control the front-end data collection infrastructure across our study websites.

Third-Party Attribution by CCPA Applicability. Within this concentrated ecosystem, CCPA-Subject and CCPA-Not-Subject websites exhibit comparable overall third-party script-set cookie rates (40.0% vs. 41.1%, χ^2 , n.s.), as shown in Table 2. The difference is most pronounced for Targeting cookies: 51.0% of Targeting cookies on CCPA-Subject websites are set by third-party scripts, compared to 45.0% on CCPA-Not-Subject websites ($p < 0.001$, $V = 0.06$). In contrast, CCPA-Not-Subject websites show higher third-party rates for Performance and Functional cookies. Because third-party Targeting cookies are a common initial mechanism for user data collection and cross-site tracking, their prevalence among CCPA-Subject websites provides an important signal for auditing.

Privacy Configuration Effects on Third-Party Tracking. Privacy-enhancing configurations demonstrate varying effectiveness in mitigating third-party cookies, as shown in Table 2. The uBlock configuration achieves the most substantial reduction in third-party cookies, reducing by 82% for CCPA-Subject websites and 89% for CCPA-Not-Subject websites. The GPC signal also demonstrates meaningful effectiveness, reducing third-party cookies by 37% for CCPA-Subject websites and 31% for CCPA-Not-Subject websites. However, GPC’s effectiveness remains incomplete: *despite GPC’s legal mandate under CCPA for CCPA-Subject businesses to honor opt-out requests, GPC reduces third-party Targeting cookies by only 41% for CCPA-Subject websites*. Our study reveals that the GPC disproportionately results in reduced true first-party cookies (66% reduction) while retaining more cookies set by third-party scripts (only 40.3% reduction). This persistence matters because third-party scripts executing on a visited site can read first-party-scoped cookies locally and transmit identifiers to their own servers, enabling cross-site correlation through identifier smuggling [11, 95].

Takeaway 4. Third-party tracking on CCPA-Subject websites is widespread, script-driven, and concentrated.

4.3 Auditing Disclosures vs. Tracking

Finally, we link PrivAudit’s policy audits with per-website cookie measurements to identify audit signals that combine what websites disclose with what users can observe at first visit.

GPC disclosures. Websites that claim to honor GPC often continue setting Targeting cookies when GPC is enabled. Among CCPA-Subject policies, 28.7% (163 sites) claim to honor GPC. Of these, 151 have matched cookie data, and 110 set Targeting cookies in both Default and GPC configurations. Among these 110 sites, 52.7% (58 sites) show less than a 20% reduction in Targeting cookies under GPC, and 39.1% (43 sites) show no reduction at all. The gap is even more pronounced for third-party Targeting cookies: among sites that set third-party Targeting cookies in both configurations, 66.2% show less than a 20% reduction, and 47.5% show no reduction. These disclosure-behavior gaps provide a strong audit signal because they resemble issues raised in prior enforcement actions such as *People v. Sephora*, which involved alleged sale of personal information through online tracking technologies, including cookies, and failure to process GPC opt-out requests [21]. The same gap appears among CCPA-Not-Subject websites: of the 46 that claim to honor GPC and set cookies, 67% (31) still set at least one third-party Targeting cookie at initial load, and 61% do so even when GPC is sent.

Data selling disclosures. 204 (36.0%) CCPA-Subject policies explicitly state they do not sell personal data. Of the 187 such sites that set cookies, 50.8% (95 sites) nonetheless deploy third-party targeting cookies at initial load, and 23.5% (44 sites) set five or more such cookies. While cookies alone do not constitute a “sale” under the CCPA (§3.3), third-party targeting cookies are the primary technical mechanism through which cross-site data sharing is initiated [46], making their co-occurrence with no-sale disclosures an important signal for further manual review.

Required disclosures. The CCPA requires a policy to disclose the categories of personal information a business collects (§1798.130(a)(5)(B)(i)) and those it sells or shares, or a statement that it does neither (§1798.130(a)(5)(C)(i)). Combining both lenses lets us check these mandates against observed behavior: of the 269 CCPA-Subject websites that set third-party Targeting cookies at initial load, 26 (9.7%) do not disclose any data collection, and 22 (8.2%) disclose neither the sale nor the sharing of personal information (29 under a stricter reading). Because setting third-party Targeting cookies is precisely the collection and sharing these provisions ask businesses to disclose, the co-occurrence of tracking with absent required disclosures is an important signal for further manual review.

Policy quality. High-quality privacy policies do not necessarily correspond to lower cookie-based tracking. Even among the 394 CCPA-Subject websites in our dataset with high-quality privacy policies (completeness and usability scores ≥ 2), 43.7% (172 sites) set five or more Targeting cookies on first visit. The median Targeting cookie count for these high-quality-policy sites is identical to the population median, indicating that stronger disclosures are not associated with reduced cookie-based tracking.

Takeaway 5. CCPA-Subject websites place third-party tracking cookies even when policies claim to honor privacy signals, state they do not sell data, or provide high-quality disclosures.

5 Discussion

The impact of the CCPA on privacy practices. Our results show that many CCPA-Not-Subject websites provide high quality privacy disclosures, explicitly referencing the CCPA despite lacking clear legal obligations to do so. This spillover suggests that the statute exerts influence over privacy communication beyond its formal scope. We hypothesize that this ripple effect is partially driven by the difficulty of precisely determining CCPA applicability, as observed in both our work and prior work in gathering website subjectivity information [109]. Given the ambiguities in scope, firms may strategically over-comply to mitigate risk. While this arguably raises the baseline for user transparency, it also imposes non-trivial compliance costs on organizations and complicates enforcement. This problem is exacerbated by a fragmented landscape where multiple state-level privacy laws with unique applicability criteria co-exist.

We also find that both CCPA-Subject and CCPA-Not-Subject websites engage in cookie writes, especially from third-parties, at comparable levels. This finding is partly consistent with the CCPA’s design: the statute regulates the *sale or sharing* of user information and opt-out honoring, not cookie-writes themselves. However, cookie writes are a necessary *precondition* for privacy practices regulated by the CCPA. Our findings highlighting the widespread deployment of third-party targeting cookies and the incomplete response to opt-out signals raise a critical question: *Should the CCPA expand its legal definition to granular data collection practices, including cookies, mirroring the GDPR?* We argue in the affirmative, since such regulation could (1) offer meaningful benefits to users by preventing the initial layer of data collection, (2) encourage greater front-end transparency from websites, and (3) enable faster third-party auditing of non-compliance, such as through PrivAudit.

Multi-Layer Auditing. Combining auditing of disclosures with tracking behavior allows PrivAudit to surface audit-relevant patterns, such as websites that claim to honor GPC while continuing to set third-party cookies when the GPC is set. Such signals are useful precisely because regulators and researchers cannot manually inspect every website, policy, consent interface, and tracking configuration at scale. PrivAudit’s outputs do not replace legal analysis and enforcement, but can inform audit selection, public reporting, rulemaking, and future enforcement priorities. We make PrivAudit open-source (see Appendix B) and are actively engaging with regulators and legal experts to explore use-cases in regulatory auditing. In addition, we also believe PrivAudit can be useful as a self-auditing tool for website developers and privacy teams as it can translate dense legal requirements into structured policy checks and browser measurements.

Implications Beyond the CCPA. Although our analysis focuses on the CCPA, the gaps we document are unlikely to be unique to California. More than 20 U.S. states have enacted CCPA-like privacy laws [68], many with similar opt-out frameworks and universal

opt-out signals such as GPC. The 2025 multi-state GPC enforcement sweep by California, Colorado, and Connecticut [27] further suggests that regulators view incomplete opt-out honoring as a shared concern. Future research can extend PrivAudit's rubric and crawling infrastructure to newer state laws [53, 54, 88].

Limitations. While PrivAudit automates much of our policy and cookie analysis, it still requires manual effort to engineer and validate LLM prompts, which remains necessary to reduce hallucinations. Although prior work shows that internal pages can differ from landing pages in resource composition and tracking behavior [8], we verify that homepages capture roughly 87–90% of the third-party Targeting trackers on a typical internal page across all six configurations, so homepage-only measurement does not severely undercount tracking (Appendix K). Our measurements nonetheless remain limited to cookies observable without authenticated or interaction-gated flows (e.g., login, scrolling), which we leave to future work. Additionally, our analysis focuses on cookie-based tracking, which is prominent but only one mechanism for user data collection. PrivAudit can be extended to other user-facing techniques such as browser fingerprinting [1, 45] and CNAME cloaking [41] that can complement or bypass cookie-based tracking in future work. Our results represent a single crawl conducted in mid-2025, and cookie-setting behavior may vary across sessions due to temporal changes in tracking infrastructure. However, prior longitudinal studies have found that both the structure of the tracking ecosystem and GPC compliance rates remain relatively stable over short periods [61, 104]. Despite these limitations, we believe PrivAudit provides a strong foundation for repeatable and automated auditing of privacy practices.

Acknowledgments

We thank the anonymous reviewers for their constructive feedback. We are grateful to Sabrina Ross for her expert insights and review of this work. We also thank Reethika Ramesh and Hieu Le for their valuable feedback, as well as Isa Abello, Kenneth Lai, Kelvin Chan, and other members of our research group for their insights.

References

- [1] Gunes Acar, Christian Eubank, Steven Englehardt, Marc Juarez, Arvind Narayanan, and Claudia Diaz. 2014. The web never forgets: Persistent tracking mechanisms in the wild. In *ACM conference on computer and communications security*.
- [2] Abdulaziz Alghamdi and David Mohaisen. 2024. Through the Looking Glass: LLM-Based Analysis of AR/VR Android Applications Privacy Policies. In *International Conference on Machine Learning and Applications (ICMLA)*.
- [3] Mir Masood Ali, David G Balash, Monica Kodwani, Chris Kanich, and Adam J Aviv. 2024. Honesty is the best policy: On the accuracy of apple privacy labels compared to apps' privacy policies. In *Privacy Enhancing Technologies Symposium*.
- [4] Abdul Haddi Amjad, Danial Saleem, Muhammad Ali Gulzar, Zubair Shafiq, and Fareed Zaffar. 2021. Trackersift: Untangling mixed tracking and functional web resources. In *ACM Internet Measurement Conference*.
- [5] Benjamin Andow, Samin Yaseer Mahmud, Wenyu Wang, Justin Whitaker, William Enck, Bradley Reaves, Kapil Singh, and Tao Xie. 2019. PolicyLint: investigating internal privacy policy contradictions on google play. In *USENIX security symposium*.
- [6] Benjamin Andow, Samin Yaseer Mahmud, Justin Whitaker, William Enck, Bradley Reaves, Kapil Singh, and Serge Egelman. 2020. PActions speak louder than words: Entity-Sensitive privacy policy and data flow analysis with PoliCheck. In *USENIX Security Symposium*.
- [7] Apollo.io. 2026. Apollo. <https://www.apollo.io/>.
- [8] Waqar Aqeel, Balakrishnan Chandrasekaran, Anja Feldmann, and Bruce M Maggs. 2020. On landing and internal web pages: The strange case of jekyll and hyde in web performance measurement. In *ACM Internet Measurement Conference*.
- [9] Ron Artstein and Massimo Poesio. 2008. Survey article: Inter-coder agreement for computational linguistics. *Computational linguistics* 34, 4 (2008).
- [10] Muhammad Abu Bakar Aziz and Christo Wilson. 2024. Johnny Still Can't Opt-out: Assessing the IAB CCPA Compliance Framework. *Proceedings on Privacy Enhancing Technologies* (2024).
- [11] Pouneh Nikkha Bahrami, Aurore Fass, and Zubair Shafiq. 2025. CookieGuard: Characterizing and Isolating the First-Party Cookie Jar. In *Proceedings of the 2025 ACM Internet Measurement Conference (IMC '25)*.
- [12] Jeeyun Sophia Baik. 2020. Data privacy against innovation or against discrimination?: The case of the California Consumer Privacy Act (CCPA). *Telematics and Informatics* 52 (2020).
- [13] Yoav Benjamini and Yosef Hochberg. 1995. Controlling the false discovery rate: a practical and powerful approach to multiple testing. *Journal of the Royal statistical society: series B (Methodological)* (1995).
- [14] Eleanor Birrell, Jay Rodolitz, Angel Ding, Jenna Lee, Emily McReynolds, Jevan Hutson, and Ada Lerner. 2024. Sok: Technical implementation and human impact of internet privacy regulations. In *IEEE Symposium on Security and Privacy*.
- [15] Dino Bollinger, Karel Kubicek, Carlos Cotrini, and David Basin. 2022. Automating cookie consent and GDPR violation detection. In *USENIX Security Symposium*.
- [16] Ahmed Bouhoula, Karel Kubicek, Amit Zac, Carlos Cotrini, and David Basin. 2024. Automated Large-Scale Analysis of Cookie Notice Compliance. In *USENIX Security Symposium*.
- [17] Elijah Robert Bouma-Sims, Megan Li, Yanzi Lin, Adia Sakura-Lemessy, Alexandra Nisenoff, Ellie Young, Eleanor Birrell, Lorrie Faith Cranor, and Hana Habib. 2023. A US-UK usability evaluation of consent management platform cookie consent interface design on desktop and mobile. In *ACM CHI*.
- [18] Kevin Bryson, Arthur Borem, Phoebe Moh, Omer Akgul, Laura Edelson, Tobias Lauinger, Michelle L Mazurek, Damon McCoy, and Blase Ur. 2025. Characterizing the usability and usefulness of us ad transparency systems. In *2025 IEEE Symposium on Security and Privacy*. IEEE.
- [19] Duc Bui, Brian Tang, and Kang G Shin. 2023. Detection of inconsistencies in privacy practices of browser extensions. In *IEEE Symposium on Security and Privacy*.
- [20] Aaron Cahn, Scott Alfeld, Paul Barford, and Shanmugavelayutham Muthukrishnan. 2016. An empirical study of web cookies. In *International Conference on World Wide Web*.
- [21] California Department of Justice. 2022. Attorney General Bonta Announces Settlement with Sephora as Part of Ongoing Enforcement of California Consumer Privacy Act. Press Release. <https://oag.ca.gov/news/press-releases/attorney-general-bonta-announces-settlement-sephora-part-ongoing-enforcement>
- [22] California Department of Justice. 2025. Attorney General Bonta Announces Largest CCPA Settlement to Date, Secures \$1.55 Million from Healthline.com. Press Release. <https://oag.ca.gov/news/press-releases/attorney-general-bonta-announces-largest-ccpa-settlement-date-secures-155>
- [23] California Department of Justice. 2026. California Won't Let It Go: Attorney General Bonta Announces \$2.75 Million Settlement with Disney. Press Release. <https://oag.ca.gov/news/press-releases/california-wont-let-it-go-attorney-general-bonta-announces-275-million>
- [24] California Department of Justice, Office of the Attorney General. 2025. CCPA Enforcement Case Examples. <https://oag.ca.gov/privacy/ccpa/enforcement>. Accessed: 2025-11-14.
- [25] California Privacy Protection Agency. 2024. 2024–2027 Strategic Plan. https://cppa.ca.gov/pdf/strategic_plan_2024_2027.pdf.
- [26] California Privacy Protection Agency. 2024. From Vision to Reality: CPPA's Inaugural Annual Report. https://cppa.ca.gov/pdf/2024_annual_report.pdf.
- [27] California Privacy Protection Agency. 2025. California Privacy Protection Agency Announces Joint Investigative Privacy Sweep. Press Release. <https://cppa.ca.gov/announcements/2025/20250909.html>
- [28] California Privacy Protection Agency. 2025. Honda Settles With CPPA Over Privacy Violations. Enforcement Action. <https://cppa.ca.gov/announcements/2025/20250312.html>
- [29] California Privacy Protection Agency. 2025. Nation's Largest Rural Lifestyle Retailer to Pay \$1.35M Over CCPA Violations. Enforcement Action. <https://cppa.ca.gov/announcements/2025/20250930.html>
- [30] Jan Charatan and Eleanor Birrell. 2024. Two Steps Forward and One Step Back: The Right to Opt-out of Sale under CPRA. *Proceedings on Privacy Enhancing Technologies (PoPETs)* (2024).
- [31] Quan Chen, Panagiotis Ilia, Michalis Polychronakis, and Alexandros Kapravelos. 2021. Cookie swap party: Abusing first-party cookies for web tracking. In *The Web Conference*.
- [32] Rex Chen, Fei Fang, Thomas Norton, Aleecia M McDonald, and Norman Sadeh. 2021. Fighting the fog: Evaluating the clarity of privacy disclosures in the age of CCPA. In *Proceedings of the 20th Workshop on Workshop on Privacy in the Electronic Society*.

- [33] Giovanni Ciaramella, Luca Petrillo, Margaret Varilek, Francesco Mercaldo, Giovanni Comand , and Fabio Martinelli. 2025. Leveraging Pre-trained LLMs for GDPR Compliance in Online Privacy Policies. *Joint National Conference on Cybersecurity (ITASEC & SERICS)* (2025).
- [34] Cookiepedia. 2025. Largest Database of Pre-Categorized Cookies. <https://cookiepedia.co.uk/>.
- [35] Hao Cui, Rahmadi Trimnanda, and Athina Markopoulou. 2025. Understanding privacy norms through web forms. In *Privacy Enhancing Technologies Symposium*.
- [36] Hao Cui, Rahmadi Trimnanda, Athina Markopoulou, and Scott Jordan. 2023. PoliGraph: Automated privacy policy analysis using knowledge graphs. In *USENIX Security Symposium*.
- [37] Martin Degeling, Christine Utz, Christopher Lentzsch, Henry Hosseini, Florian Schaub, and Thorsten Holz. 2019. We Value Your Privacy ... Now Take Some Cookies: Measuring the GDPR's Impact on Web Privacy. In *Network and Distributed System Security Symposium*.
- [38] Nurullah Demir, Daniel Theis, Tobias Urban, and Norbert Pohlmann. 2022. Towards understanding first-party cookie tracking in the field. In *GI Sicherheit*.
- [39] Nurullah Demir, Tobias Urban, Norbert Pohlmann, and Christian Wressnegger. 2024. A Large-Scale Study of Cookie Banner Interaction Tools and their Impact on Users' Privacy. *Proceedings on Privacy Enhancing Technologies* (2024).
- [40] Rinku Dewri. 2025. Interpretation Gaps in LLM-Assisted Comprehension of Privacy Documents. *Computer* (2025).
- [41] Yana Dimova, Gunes Acar, Lukasz Olejnik, Wouter Joosen, and Tom Van Goethem. 2021. The CNAME of the Game: Large-scale Analysis of DNS-based Tracking Evasion. In *Privacy Enhancing Technologies*.
- [42] Disconnect. 2021. Disconnect Tracking Protection Lists. <https://disconnect.me/trackerprotection>. Accessed: 2025-11-14.
- [43] DuckDuckGo. 2020. DuckDuckGo Tracker Radar: Data Set of Third-Party Trackers. <https://github.com/duckduckgo/tracker-radar>. Accessed: 2025-11-14.
- [44] EasyList. 2025. EasyList - Overview. <https://easylist.to/index.html>
- [45] Peter Eckersley. 2010. How unique is your web browser?. In *Privacy Enhancing Technologies Symposium*.
- [46] Steven Englehardt and Arvind Narayanan. 2016. Online tracking: A 1-million-site measurement and analysis. In *ACM Conference on Computer and Communications Security*.
- [47] Steven Englehardt, Dillon Reisman, Christian Eubank, Peter Zimmerman, Jonathan Mayer, Arvind Narayanan, and Edward W Felten. 2015. Cookies that give you away: The surveillance implications of web tracking. In *International Conference on World Wide Web*.
- [48] Olivia Figueira, Rahmadi Trimnanda, Athina Markopoulou, and Scott Jordan. 2024. Diffaudit: Auditing privacy practices of online services for children and adolescents. In *ACM on Internet Measurement Conference*.
- [49] Imane Fouad, Cristiana Santos, and Pierre Laperdrix. 2024. The devil is in the details: detection, measurement and lawfulness of server-side tracking on the web. In *Privacy Enhancing Technologies Symposium*.
- [50] Imane Fouad, Cristiana Santos, Arnaud Legout, and Nataliia Bielova. 2022. My Cookie is a phoenix: detection, measurement, and lawfulness of cookie respawning with browser fingerprinting. In *Privacy Enhancing Technologies Symposium*.
- [51] Vincent Freiburger, Arthur Fleig, and Erik Buchmann. 2025. "You don't need a university degree to comprehend data protection this way": LLM-Powered Interactive Privacy Policy Assessment. In *Conference on Human Factors in Computing Systems Extended Abstracts*.
- [52] California Attorney General. 2018. California Consumer Privacy Act (CCPA). <https://oag.ca.gov/privacy/ccpa>.
- [53] Colorado Attorney General. 2021. Colorado Privacy Act, Colo. Rev. Stat.  6-1-1301 et seq. <https://coag.gov/resources/colorado-privacy-act/>.
- [54] Virginia Attorney General. 2023. Virginia OAG Summary of the VCDPA. <https://www.oag.state.va.us/consumer-protection/files/tips-and-info/Virginia-Consumer-Data-Protection-Act-Summary-2-2-23.pdf>.
- [55] Global Legal Entity Identifier Foundation. 2026. GLEIF Legal Entity Data. <https://www.gleif.org/>.
- [56] Global Privacy Control Contributors. 2024. Global Privacy Control (GPC) Specification. <https://globalprivacycontrol.org/>.
- [57] Giulia Grundler, R ta Liepina, Mariaceleste Musiccio, Francesca Lagioia, Andrea Galassi, Giovanni Sartor, and Paolo Torroni. 2024. Detecting Vague Clauses in Privacy Policies: The Analysis of Data Categories Using BERT Models and LLMs. In *Legal Knowledge and Information Systems*.
- [58] Johanna Gunawan, Cristiana Santos, and Irene Kamara. 2022. Redress for dark patterns privacy harms? A case study on consent interactions. In *Symposium on Computer Science and Law*.
- [59] Hana Habib and Lorrie Faith Cranor. 2022. Evaluating the usability of privacy choice mechanisms. In *Symposium on Usable Privacy and Security*.
- [60] Hana Habib, Megan Li, Ellie Young, and Lorrie Cranor. 2022. "Okay, whatever": An evaluation of cookie consent interfaces. In *Conference on Human Factors in Computing Systems*.
- [61] Katherine Hausladen, Oliver Wang, Sophie Eng, Jocelyn Wang, Francisca Wijaya, Matthew May, and Sebastian Zimmeck. 2025. Websites' Global Privacy Control Compliance at Scale and over Time. In *USENIX Security Symposium*.
- [62] Le Hieu, Markopoulou Athina, and Shafiq Zubair. 2021. Cv-inspector: Towards automating detection of adblock circumvention. In *Network and Distributed System Security Symposium*.
- [63] Sture Holm. 1979. A simple sequentially rejective multiple test procedure. *Scandinavian journal of statistics* (1979).
- [64] Stefan Albert Horstmann, Sandy Hong, David Klein, Raphael Serafini, Martin Degeling, Martin Johns, Veelasha Moonsamy, and Alena Naiakshina. 2025. "Sorry for Bugging you so much." Exploring Developers' Behavior Towards Privacy-Compliant Implementation. In *IEEE Symposium on Security and Privacy*.
- [65] Henry Hosseini, Christine Utz, Martin Degeling, and Thomas Hupperich. 2024. A bilingual longitudinal analysis of privacy policies measuring the impacts of the GDPR and the CCPA/CPRA. In *Privacy Enhancing Technologies*.
- [66] Xuehui Hu, Nishanth Sastry, and Mainack Mondal. 2021. Cccc: Corraling cookies into categories with cookiemonster. In *ACM Web Science Conference*.
- [67] Ziyuan Huang, Jiaming Tang, Manish Karir, Mingyan Liu, and Armin Sarabi. 2024. Analyzing corporate privacy policies using AI chatbots. In *ACM Internet Measurement Conference*.
- [68] IAPP. 2025. US State Privacy Legislation Tracker. <https://iapp.org/resources/article/us-state-privacy-legislation-tracker/>
- [69] Umar Iqbal, Peter Snyder, Shitong Zhu, Benjamin Livshits, Zhiyun Qian, and Zubair Shafiq. 2020. Adgraph: A graph-based approach to ad and tracker blocking. In *IEEE Symposium on security and privacy*.
- [70] Soha Jiwani, Rachna Sasheendran, Adhishree Abhyankar, Elijah Bouma-Sims, and Lorrie Cranor. 2024. Crumbling cookie categories: Deconstructing common cookie categories to create categories that people understand. In *Privacy Enhancing Technologies*.
- [71] Kaushal Kafle, Prianka Mandal, Kapil Singh, Benjamin Andow, and Adwait Nadkarni. 2024. Understanding the privacy practices of political campaigns: A perspective from the 2020 us election websites. In *IEEE Symposium on Security and Privacy*.
- [72] J Richard Landis and Gary G Koch. 1977. The measurement of observer agreement for categorical data. *Biometrics* (1977).
- [73] Shuai Li, Zhemin Yang, Yuhong Nan, Shutian Yu, Qirui Zhu, and Min Yang. 2024. Are We Getting Well-informed? An In-depth Study of Runtime Privacy Notice Practice in Mobile Apps. In *ACM Conference on Computer and Communications Security*.
- [74] Timothy Libert. 2018. An automated approach to auditing disclosure of third-party data collection in website privacy policies. In *World Wide Web Conference*.
- [75] Zengrui Liu, Umar Iqbal, and Nitesh Saxena. 2024. Opted Out, Yet Tracked: Are Regulations Enough to Protect Your Privacy?. In *Privacy Enhancing Technologies*.
- [76] Dominique Machuletz and Rainer B hme. 2020. Multiple Purposes, Multiple Problems: A User Study of Consent Dialogs after GDPR. In *Privacy Enhancing Technologies*.
- [77] C lestin Matte, Nataliia Bielova, and Cristiana Santos. 2020. Do cookie banners respect my choice?: Measuring legal compliance of banners from iab europe's transparency and consent framework. In *IEEE Symposium on Security and Privacy*.
- [78] Torsha Mazumdar, Daniel Timko, and Muhammad Lutfur Rahman. 2023. Are Current CCPA Compliant Banners Conveying User's Desired Opt-Out Decisions? An Empirical Study of Cookie Consent Banners. In *International Conference on Cryptology and Network Security*.
- [79] Abraham Mhaidli, Selin Fidan, An Doan, Gina Herakovic, Mukund Srinath, Lee Matheson, Shomir Wilson, and Florian Schaub. 2023. Researchers' experiences in analyzing privacy policies: Challenges and opportunities. In *Privacy Enhancing Technologies*.
- [80] Victor Morel, Cristiana Santos, Yvonne Lintao, and Soheil Human. 2022. Your consent is worth 75 euros a year-measurement and lawfulness of cookie paywalls. In *Workshop on Privacy in the Electronic Society*.
- [81] Keika Mori, Daiki Ito, Takumi Fukunaga, Takuya Watanabe, Yuta Takata, Masaki Kamizono, and Tatsuya Mori. 2025. Evaluating LLMs Towards Automated Assessment of Privacy Policy Understandability. In *Proceedings of the 2025 Symposium on Usable Security and Privacy*.
- [82] Mozilla Contributors. 2025. Navigator: globalPrivacyControl property. <https://developer.mozilla.org/en-US/docs/Web/API/Navigator/globalPrivacyControl>.
- [83] Shaor Munir, Sandra Siby, Umar Iqbal, Steven Englehardt, Zubair Shafiq, and Carmela Troncoso. 2023. Cookiegraph: Understanding and detecting first-party tracking cookies. In *ACM Conference on Computer and Communications Security*.
- [84] Midas Nouwens, Rolf Bagge, Janus Bager Kristensen, and Clemens Nylandsted Klokmoose. 2022. Consent-o-Matic: Automatically answering consent pop-ups using adversarial interoperability. In *Conference on Human Factors in Computing Systems Extended Abstracts*.
- [85] Midas Nouwens, Janus Bager Kristensen, Kristjan Maalt, and Rolf Bagge. 2025. A Cross-Country Analysis of GDPR Cookie Banners and Flexible Methods For Scraping Them. In *Conference on Human Factors in Computing Systems*.

- [86] Midas Nouwens, Ilaria Lliccardi, Michael Veale, David Karger, and Lalana Kagal. 2020. Dark patterns after the GDPR: Scraping consent pop-ups and demonstrating their influence. In *Conference on human factors in computing systems*.
- [87] Sean O'Connor, Ryan Nurwono, Aden Siebel, and Eleanor Birrell. 2021. (Un) clear and (In) conspicuous: The right to opt-out of sale under CCPA. In *Workshop on Privacy in the Electronic Society (WPES)*.
- [88] Utah Department of Commerce. 2023. Utah Consumer Privacy Act Overview (Utah DCP). <https://dcp.utah.gov/ucpa/>.
- [89] Office of the Attorney General, State of California. 2025. Global Privacy Control (GPC) under the CCPA. <https://oag.ca.gov/privacy/ccpa/gpc>.
- [90] Open-Cookie-Database. 2025. Open Cookie Database (GitHub). <https://github.com/jkwakman/Open-Cookie-Database/blob/master/open-cookie-database.csv>.
- [91] Shidong Pan, Zhen Tao, Thong Hoang, Dawen Zhang, Tianshi Li, Zhenchang Xing, Xiwei Xu, Mark Staples, Thierry Rakotoarivelo, and David Lo. 2024. A NEW HOPE: Contextual privacy policies for mobile applications and an approach toward automated generation. In *USENIX Security Symposium*.
- [92] Shidong Pan, Dawen Zhang, Mark Staples, Zhenchang Xing, Jieshan Chen, Xiwei Xu, and Thong Hoang. 2024. Is it a trap? a large-scale empirical study and comprehensive assessment of online automated privacy policy generators for mobile apps. In *USENIX Security Symposium*.
- [93] Panagiotis Papadopoulos, Nicolas Kourtellis, and Evangelos Markatos. 2019. Cookie synchronization: Everything you always wanted to know but were afraid to ask. In *The World Wide Web Conference*.
- [94] Victor Le Pochat, Tom Van Goethem, Samaneh Tajalizadehkhoob, Maciej Korczynski, and Wouter Joosen. 2019. Tranco: A Research-Oriented Top Sites Ranking Hardened Against Manipulation. In *Network and Distributed System Security Symposium*.
- [95] Audrey Randall, Peter Snyder, Alisha Ukani, Alex C Snoeren, Geoffrey M Voelker, Stefan Savage, and Aaron Schulman. 2022. Measuring UID smuggling in the wild. In *ACM Internet Measurement Conference*.
- [96] Ali Rasaii, Ha Dao, Anja Feldmann, Mohammadmahdi Javid, Oliver Gasser, and Devashish Gosain. 2025. Intractable Cookie Crumbs: Unveiling the Nexus of Stateful Banner Interaction and Tracking Cookies. In *Privacy Enhancing Technologies*.
- [97] Ali Rasaii, Shivani Singh, Devashish Gosain, and Oliver Gasser. 2023. Exploring the cookieverse: A multi-perspective analysis of web cookies. In *International Conference on Passive and Active Network Measurement*.
- [98] David Rodriguez, Ian Yang, Jose M Del Alamo, and Norman Sadeh. 2024. Large language models: a new approach for privacy policy analysis at scale. In *Computing*.
- [99] Franziska Roesner, Tadayoshi Kohno, and David Wetherall. 2012. Detecting and defending against Third-Party tracking on the web. In *USENIX Symposium on Networked Systems Design and Implementation*.
- [100] Rohan Charudatt Salvi, Catherine Blake, and Masooda Bahir. 2024. Privacychat: Utilizing large language model for fine-grained information extraction over privacy policies. In *International Conference on Information*.
- [101] Lorin Schöni, Karel Kubicek, and Verena Zimmermann. 2023. Block Cookies, Not Websites: Analysing Mental Models and Usability of the Privacy-Preserving Browser Extension CookieBlock. In *Privacy Enhancing Technologies*.
- [102] Aden Siebel and Eleanor Birrell. 2022. The Impact of Visibility on the Right to Opt-out of Sale under CCPA. *arXiv preprint arXiv:2206.10545* (2022).
- [103] Michael Smith, Antonio Torres-Aguero, Riley Grossman, Pritam Sen, Yi Chen, and Cristian Borcea. 2024. A study of gdpr compliance under the transparency and consent framework. In *Proceedings of the ACM Web Conference 2024*.
- [104] Konstantinos Solomos, Panagiotis Ilia, Sotiris Ioannidis, and Nicolas Kourtellis. 2020. Clash of the Trackers: Measuring the Evolution of the Online Tracking Ecosystem. In *Network Traffic Measurement and Analysis Conference (TMA)*.
- [105] State of California. 2023. California Civil Code, Section 1798.140 — Definitions. https://leginfo.ca.gov/faces/codes_displaySection.xhtml?lawCode=CIV§ionNum=1798.140.
- [106] Andreas Stenwreth, Simon Tang, and Victor Morel. 2024. To Be or Not to Be (in the EU): Measurement of Discrepancies Presented in Cookie Paywalls (LONG). *arXiv preprint arXiv:2410.06920* (2024).
- [107] Brian Tang, Duc Bui, and Kang G Shin. 2025. Navigating Cookie Consent Violations Across the Globe. *USENIX Security Symposium* (2025).
- [108] Chenhao Tang, Zhengliang Liu, Chong Ma, Zihao Wu, Yiwei Li, Wei Liu, Dajiang Zhu, Quanzheng Li, Xiang Li, Tianming Liu, et al. 2023. PolicyGPT: Automated analysis of privacy policies with large language models. *arXiv preprint arXiv:2309.10238* (2023).
- [109] Van Hong Tran, Aarushi Mehrotra, Marshini Chetty, Nick Feamster, Jens Frankeneiter, and Lior Strahilevitz. 2024. Measuring compliance with the california consumer privacy act over space and time. In *ACM CHI*.
- [110] Van Hong Tran, Aarushi Mehrotra, Ranya Sharma, Marshini Chetty, Nick Feamster, Jens Frankeneiter, and Lior Strahilevitz. 2025. Dark Patterns in the Opt-Out Process and Compliance with the California Consumer Privacy Act (CCPA). In *Conference on Human Factors in Computing Systems*.
- [111] Rahmadi Trimnanda, Hieu Le, Hao Cui, Janice Tran Ho, Anastasia Shuba, and Athina Markopoulou. 2022. OVRseen: Auditing network traffic and privacy policies in oculus. In *USENIX security symposium*.
- [112] European Union. 2016. Regulation (EU) 2016/679 of the European Parliament and of the Council — General Data Protection Regulation (GDPR). <https://gdpr-info.eu/> Accessed: 2025-05-07.
- [113] Tobias Urban, Martin Degeling, Thorsten Holz, and Norbert Pohlmann. 2020. Beyond the Front Page: Measuring Third Party Dynamics in the Field. In *Proceedings of The Web Conference 2020*.
- [114] U.S. Securities and Exchange Commission. 2026. EDGAR. <https://www.sec.gov/edgar>.
- [115] Christine Utz, Martin Degeling, Sascha Fahl, Florian Schaub, and Thorsten Holz. 2019. (Un) informed consent: Studying GDPR consent notices in the field. In *ACM Conference on Computer and Communications Security*.
- [116] Maggie Van Nortwick and Christo Wilson. 2022. Setting the bar low: Are websites complying with the minimum requirements of the CCPA?. In *Privacy Enhancing Technologies*.
- [117] Isabel Wagner. 2023. Privacy policies across the ages: content of privacy policies 1996–2021. *ACM Transactions on Privacy and Security* 26, 3 (2023).
- [118] Wikimedia Foundation. 2026. Wikidata. <https://www.wikidata.org/>.
- [119] Justin Woodring, Katherine Perez, and Aisha Ali-Gombe. 2024. Enhancing privacy policy comprehension through privacyfy: A user-centric approach using advanced language models. *Computers & Security* (2024).
- [120] Lu Xian, Van Tran, Lauren Lee, Meera Kumar, Yichen Zhang, and Florian Schaub. 2025. Layered, Overlapping, and Inconsistent: A Large-Scale Analysis of the Multiple Privacy Policies and Controls of US Banks. *USENIX Symposium on Usable Privacy and Security* (2025).
- [121] Qing Xie, Karthik Ramakrishnan, and Frank Li. 2025. Evaluating privacy policies under modern privacy laws at scale: An LLM-Based automated approach. In *USENIX Security Symposium*.
- [122] Eric Zeng, Xiaoyuan Wu, Emily N Ertmann, Lily Huang, Danielle F Johnson, Anusha T Mehendale, Brandon T Tang, Karolina Zhukoff, Michael Adjei-Poku, Lujo Bauer, et al. 2025. Measuring Risks to Users' Health Privacy Posed by Third-Party Web Tracking and Targeted Advertising. In *CHI Conference on Human Factors in Computing Systems*.
- [123] Mingxue Zhang, Wei Meng, You Zhou, and Kui Ren. 2024. CSChecker: revisiting GDPR and CCPA compliance of cookie banners on the web. In *Proceedings of the IEEE/ACM 46th International Conference on Software Engineering*.
- [124] Sebastian Zimmeck, Nishant Aggarwal, Zachary Liu, and Konrad Kollnig. 2024. From Ad Identifiers to Global Privacy Control: The Status Quo and Future of Opting Out of Ad Tracking on Android. *arXiv preprint arXiv:2407.14938* (2024).
- [125] Sebastian Zimmeck, Oliver Wang, Kuba Alicki, Jocelyn Wang, and Sophie Eng. 2023. Usability and enforceability of global privacy control. In *Privacy Enhancing Technologies*.

A Generative AI Usage

Generative AI tools (e.g. Claude) were used for grammar checking and improving readability of the manuscript. Additionally, as described in Section 3.2.2, our methodology uses LLMs (GPT-3.5, GPT-4o, and Gemini 2.5) for automated privacy policy evaluation. All content was written, reviewed, and verified by the authors.

B Open Science

All artifacts necessary to evaluate the contributions of this paper are available at <https://github.com/r-andlab/PrivAudit>. The repository contains:

- **Cookie crawler:** Puppeteer-based crawler with six privacy configuration profiles and per-website cookie banner flow definitions (crawler/).
- **Privacy policy scraper:** Selenium-based pipeline for automated discovery and extraction of privacy policy text from website homepages (policy_analysis/scraper/).
- **LLM policy analysis:** Analysis notebook, statistical significance tests, and the CCPA-specific rubric and structured LLM prompt used for policy evaluation (policy_analysis/; Appendix O).
- **Cookie categorization:** Multi-source classification pipeline (cookie_categorization/).

Table 4: Website Categorization by CCPA Applicability and Organizational Type (998 Analyzed Websites).

Category	Description	Count
Government	Public sector domains	30
Non-Profit	U.S.-based nonprofit organizations	47
Revenue Not Sufficient	For-profits below CCPA threshold	319
Subject to CCPA	For-profits meeting CCPA applicability criteria	602
Total		998

- **Banner detection:** Consent banner detection module (banner_detection/).
- **Analysis scripts:** All table and figure generation scripts for reproducing the paper’s results (analysis/).
- **Datasets** (data/data.zip): Master cookie dataset, LLM policy audit results, website classification labels, cookie data for websites with consent banners, and scraped privacy policy text files.

Artifacts not included: The cookie categorization pipeline requires raw third-party cookie classification databases (Cookiepedia, Open Cookie Database, Cookie Cutter DB) that are not included directly due to licensing. Download instructions from original sources are provided in the repository README. The categorization results are already embedded in the master dataset.

C Ethical Considerations

We conducted all crawling and analysis from our clients located in California. PrivAudit makes only a handful of requests to each public website: (1) to retrieve its privacy policy and (2) to observe the cookies set under multiple privacy configurations. In total, we issued fewer than 10 requests per site, an insignificant fraction of normal web traffic. To select internal pages, we relied on each site’s own published sitemap (the Sitemap directive in its robots.txt), or a small set of common public paths when none was available. The crawls under different privacy configurations were performed in a round-robin manner to avoid any load on the websites. We did not collect or interact with any user data other than our own, and all analysis, including data fed to LLMs, relied solely on publicly available website responses.

D Website Categorization

We provide a breakdown on the various website categories derived from Tran et al. [109] in Table 4. We consider only for-profits clearly meeting the CCPA applicability criteria as CCPA-Subject. All other categories are CCPA-Not-Subject according to CCPA guidelines.

E Scaling to Unlabeled Websites

The Popular-Website list—the 1,000 unlabeled websites in our scaling case study—was selected from the Tranco Top-1M permanent list [94] by the following protocol: (1) keep one base domain per site under generic or U.S.-oriented TLDs (.com, .org, .net, .us, .io, .co); (2) require an active homepage (HTTP 200, text/html), which removes non-consumer infrastructure such as CDN, DNS, and API endpoints; and (3) draw 250 sites per rank band (top-1k, 1k–10k, 10k–100k, 100k–1M) at random, excluding every domain in

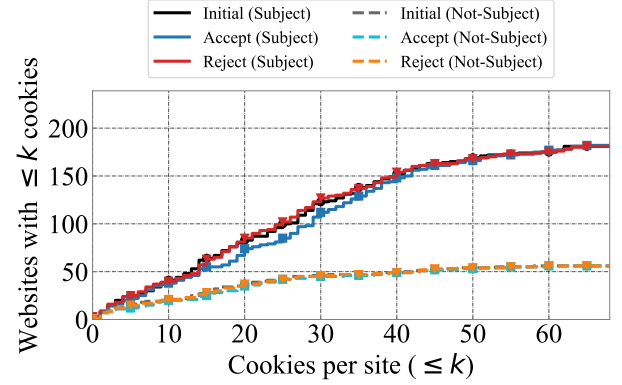


Figure 4: Distribution of per-website cookie counts for CCPA-subject websites (solid lines, N=183) and CCPA-not-subject websites (dashed lines, N=56) across consent stages (Initial, Accept, Reject).

the Known-Subjectivity list. We then run the same GPT-4o policy-scoring pipeline as our main analysis and the cookie audit under the six browser-native privacy configurations. Policies we could not retrieve fall outside the scope of our analysis.

Results. Disclosure on this corpus is weaker than on the Known-Subjectivity list: only 72% of sites expose a usable privacy policy (versus 93%), and those that do score lower on completeness, usability, and accuracy (1.65, 1.78, and 1.94 out of 3, versus 2.33, 2.29, and 2.43 for CCPA-Subject websites) and less often disclose the rights to access (40%), delete (36%), and opt out (52%) than CCPA-Subject websites (85%, 86%, and 77%); only 28% present a machine-detectable CCPA opt-out (“Do Not Sell” / “Your Privacy Choices”) mechanism. Tracking, by contrast, is more pervasive: the 740 sites that set any cookie place 7,244 in total at initial load (median 6 per site), of which 1,650 (22.8%) are *Targeting*, and 67% of all cookies (79% of Targeting cookies) are set by third-party scripts, more than the 40% on the Known-Subjectivity list (Table 2). Privacy protections follow the same pattern as on the Known-Subjectivity list: uBlock Origin removes 96% of third-party Targeting cookies and GPC reduces them by 22% ($p < 0.001$), while DNT, third-party-cookie blocking, and Consent-O-Matic show no measurable effect. The disclosure-behavior gap also appears here: among the sites whose policies claim not to sell personal data, 43.6% (99 sites) still set at least one third-party Targeting cookie at initial load, aligning with the 50.8% we report for CCPA-Subject websites in §4.3, and of the sites that present an opt-out mechanism, 54% still set a third-party Targeting cookie. These results confirm that PrivAudit’s audit signals can extend to arbitrary corpora of websites.

Takeaway 6. On the Popular-Website list (1,000 sites), privacy disclosures are weaker yet the disclosure-behavior gap persists: 43.6% of sites that claim not to sell data still set third-party Targeting cookies at first visit.

Table 5: Adoption of cookie security attributes (Default browsing configuration).

Cookie Type	N	Secure	HttpOnly	SameSite	Session
Targeting	6,392	20.2%	1.4%	20.7%	39.5%
Performance	3,464	23.1%	2.9%	15.5%	14.8%
Functional	2,094	51.9%	18.2%	24.4%	19.0%
Necessary	1,552	50.8%	11.1%	27.5%	33.0%
Unknown	5,617	16.0%	4.1%	5.2%	75.7%
Total	19,119	25.4%	5.1%	16.1%	42.9%

F Cookie Writing by Consent Flow

Consent-banner rejection provides only limited protection because many cookies are set before or despite consent interaction. Among the 239 websites with detected cookie banners, accepting cookies increases the median cookie count from 23 to 27 for CCPA-Subject websites and from 15 to 16 for CCPA-Not-Subject websites (distribution in Figure 4). Rejecting cookies, however, produces only a modest reduction for CCPA-Subject websites (23 to 22 cookies) and no change for CCPA-Not-Subject websites (15 to 15 cookies), reflecting sites that set few cookies initially but add cookies after any consent interaction. Across all consent stages, CCPA-Subject websites set roughly 50% more cookies than CCPA-Not-Subject websites.

Takeaway 7. User consent actions have limited effect on cookie collection behavior.

G Cookie Security and Privacy Characteristics

Security Attributes. Table 5 shows the percentage of cookies that adopt various security attributes such as Secure and SameSite. We observe that only 25.4% of all cookies use the Secure attribute, with significant differences between CCPA-Subject (29.1%) and CCPA-Not-Subject (19.8%) websites (χ^2 , $p < 0.001$, $V = 0.10$), and this percentage is particularly low for Targeting (20.2%) and Performance cookies (23.1%), which may contain personally identifiable information. Furthermore, the vast majority of cookies can be accessed through Javascript, as evidenced by the low adoption (5.1%) of the HttpOnly attribute across all websites, though CCPA-Subject websites show slightly higher adoption (6.4%) than CCPA-Not-Subject websites (3.0%, $p < 0.001$, $V = 0.08$). The adoption of the SameSite attribute is also relatively low (16.1%) across both CCPA-Subject and CCPA-Not-Subject websites, with no practically meaningful difference between groups ($V = 0.02$). We observe that a majority of cookies (57.1%) are set in a persistent manner rather than as session cookies, with only 39.5% of Targeting cookies set as session cookies. We see that Targeting cookies are especially long-lived, as shown in Figure 5, with a median lifespan of almost a year, whereas other types of cookies have a smaller lifespan. These findings suggest that websites prioritize long-term user tracking rather than session-based tracking, an issue exacerbated by the limited disclosure of data retention practices in privacy policies (§4.1).

Geographic and Network Information in Cookies. We examined cookie values for potential personal information (as defined by the GDPR) stored in plaintext, focusing on validated instances of geographic and network data. We identified 363 cookies (1.9% of

total) with location-related names such as geoData, zipcode, and geo, spanning 171 unique cookie identifiers. Within these cookies, we detected 7 instances of latitude/longitude coordinates, 6 ZIP codes, and 226 IP addresses. Notably 162 IP addresses appear in cookies classified as “Functional” and 28 in “Strictly Necessary” cookies, raising questions about the interpretation of necessity under CCPA. We note that this is a lower bound of personal information as we only analyze plaintext information in cookies.

Privacy-enhancing configurations demonstrate limited effectiveness in removing this sensitive information. GPC fails to reduce geographic PII, with ZIP code instances remaining constant (6 instances) and latitude/longitude coordinates actually increasing from 7 to 8 instances. IP addresses show modest reduction under GPC (15%, from 226 to 193 instances) and uBlock Origin (14%, from 226 to 195 instances). This persistence of location and network identifiers despite opt-out signals suggests that current privacy mechanisms inadequately address geolocation-based tracking.

H Delegation Through Nested Scripts

We observe that third-party cookie control frequently manifests through nested script inclusion chains. Tag management systems such as Google Tag Manager (GTM) serve as intermediaries, loading dozens of additional third-party tracking scripts that subsequently write cookies nominally scoped to the publisher’s domain. Using our call-stack instrumentation, we observed an average of 8.2 function frames in cookie-setting traces, typically reaching depths of 40–50 frames, with extreme cases exceeding 500 layers of delegation across tag managers, ad networks, and analytics frameworks. These delegation chains enable third-party scripts to set cookies with first-party domain scopes, thereby evading browser-imposed restrictions on third-party cookie access while maintaining cross-site tracking capabilities. A representative example observed on major news websites shows the _ga Google Analytics cookie—carrying a first-party domain scope—being set through a delegation chain originating from the site’s own tag manager, which loads googletagmanager.com/gtm.js, which in turn loads google-analytics.com/analytics.js that finally executes the cookie write.

Supply-Chain Concentration and Enforcement Implications.

Our analysis reveals that third-party cookie deployment is dominated by a small number of platforms: just 10 scripts from Google, Microsoft, Meta, and Adobe account for 58% of all script-set targeting cookies. This concentration suggests that improving privacy behavior may require attention not only to individual websites as in prior cases [21, 29], but also to the upstream services that deploy and manage tracking infrastructure. If major tag managers, advertising scripts, or analytics SDKs honored opt-out signals more consistently by default, the effect could propagate across many websites at once. Our script attribution exposes a layer of the tracking supply chain that is often hidden from domain-based cookie analysis performed by browsers, and can therefore support both technical defenses and regulatory oversight.

Our findings also reinforce the importance of recent work on first-party cookie defenses. CookieGuard [11] and CookieGraph [83] show that most first-party tracking cookies are written by third-party scripts, and propose mechanisms to isolate this behavior. We

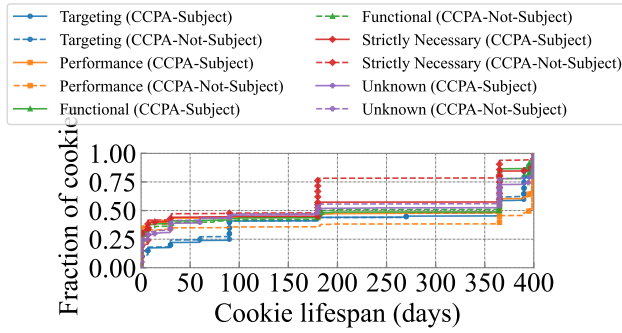


Figure 5: ECDF of per-website non-session cookie longevity by cookie type in the *Default* configuration. Solid lines represent CCPA-Subject websites and dashed lines represent CCPA-Not-Subject websites. Markers denote sample points.

extend this line of work by showing that these script-set cookies are also more resistant to privacy signals like GPC.

I Cookie Longevity

Figure 5 shows the lifespan of various types of cookies set across CCPA-Subject and CCPA-Not-Subject websites. We observe that Targeting and Performance cookies generally tend to be more long-lived, with ~50% of targeting cookies having lifetimes of almost a year. Overall, around 23.5% of cookies are short-lived (0-1 days) which are dominated by Strictly Necessary and Functional cookies, and 32.7% of cookies have a lifetime between 1-2 years. Both CCPA-Subject and CCPA-Not-Subject websites exhibit similar cookie longevity, with a median lifetime of roughly one year for each group.

J Policy and Cookie Analysis by Industry Sector

Industry Trends in Privacy Policy Analysis. Figure 6 shows the percentage of policies by industry sector that discuss behavioral claims and disclosures. The spillover of CCPA compliance to CCPA-Not-Subject websites is driven primarily by for-profit industries, which demonstrate substantially higher disclosure coverage and behavioral claims compared to Government and non-profit entities. While over 80% of for-profit websites disclose users’ rights to access and delete personal data, Government websites show dramatically lower rates (7% and 4%, respectively). This disparity is even more pronounced for privacy signals: approximately 23% of for-profit websites claim to honor GPC, while no Government websites do so, highlighting that voluntary CCPA adoption remains concentrated in the commercial sector.

Industry Trends in Cookie-based Tracking. We find that website categories vary significantly in cookie deployment strategies. Targeting cookies are especially prevalent in for-profit websites (33.8% of all cookies) compared to non-profit and government sites (24.8%), regardless of CCPA applicability. This disparity is particularly notable given that non-profit and government sectors provide the least detailed privacy policies, as discussed earlier. Within for-profit industries, those most reliant on advertising and audience tracking—such as Automotive (17.5 targeting cookies per site on

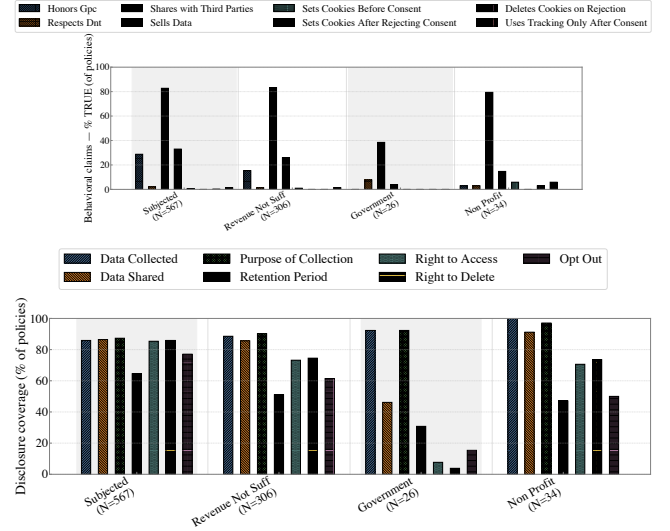


Figure 6: Rates of behavioral claims and disclosure coverage by industry sector. We observe that Government and non-profit websites tend to have lower percentages of both claims and disclosures.

Table 6: Homepage vs. internal-page third-party Targeting cookies, by privacy configuration. Negative paired differences indicate internal pages set fewer third-party Targeting cookies than the homepage. “Home captures” is the mean fraction of a *typical internal page’s* distinct third-party Targeting trackers also observed on the homepage; the value in parentheses is the stricter fraction of the *union* across all internal pages. Counts reflect the paired homepage and internal-page samples available under each configuration.

Config	Sites	Paired diff (95% CI)	Also in Home	Add none
Default	769	-0.55 [-0.75, -0.36]	87% (80%)	74%
GPC	778	-0.34 [-0.49, -0.21]	87% (78%)	77%
DNT	755	-0.68 [-0.88, -0.48]	89% (83%)	77%
Block 3P	756	-0.61 [-0.80, -0.42]	90% (83%)	78%
uBlock	850	-0.03 [-0.08, 0.02]	87% (78%)	96%
Consent-O-Matic	765	-0.58 [-0.78, -0.40]	89% (82%)	76%

average), Beauty (14.0 per site), and News Media (10.8 per site)—demonstrate substantially elevated targeting footprints.

K Internal-Page vs. Homepage Tracking

To validate that homepage measurement is representative (§4.2), we crawled up to five internal pages per site under all six privacy configurations (Default, GPC, DNT, third-party-cookie blocking, uBlock Origin, and Consent-O-Matic). Internal pages are sampled from the same-site links on the rendered homepage (excluding the homepage, static assets, and logout links, de-duplicated by path), drawing up to five at random with a per-site seed for reproducibility, following prior internal-page measurement studies [8]. Each page

Table 7: Disclosure differences persist after controlling for firm size and ad-revenue reliance. (A) Logistic-regression coefficients (log-odds) for each disclosure on CCPA subjectivity, adjusting for company annual revenue ($\log_{10}$) and ad-revenue reliance (each site’s third-party Targeting tracking intensity); $N = 816$ sites with revenue data. (B) Disclosure rates among large organizations only (annual revenue $\geq \$25M$): CCPA-subject firms vs. large but exempt organizations (nonprofits/government); $N = 563$ (528 subject, 35 exempt). * $p < 0.05$, ** $p < 0.01$, * $p < 0.001$.**

(A) Logistic regression (log-odds)			
Disclosure	CCPA Subject	$\log_{10}$ Revenue	Ad-reliance
Opt-out	+0.98***	−0.05	+0.91***
Access	+1.14***	−0.16	+0.73***
Delete	+1.15***	−0.18*	+0.73**
GPC	+0.55*	+0.17*	+0.74***
(B) Large organizations only ($\geq \$25M$ revenue)			
Disclosure	Subject	Exempt	p
Opt-out	77%	46%	<0.001
Access	85%	60%	<0.001
Delete	85%	60%	<0.001
GPC	28%	0%	<0.001

is loaded in a fresh, isolated browser context with the same script-based third-party attribution and categorization as our main crawl.

Table 6 reports, per configuration, the per-site paired difference between internal-page and homepage third-party Targeting cookies and the fraction of a site’s distinct third-party Targeting trackers already present on the homepage. Across all six configurations, internal pages set significantly fewer third-party Targeting cookies than homepages. We report two measures: the fraction of a *typical internal page*’s distinct third-party Targeting trackers already present on the homepage (87–90%), and the stricter fraction of the *union* of trackers across all internal pages captured by the homepage (78–83%). The gap between the two reflects that internal pages collectively surface a tail of additional trackers, but such tail third parties are largely non-deterministic between repeated visits [113], so the per-page measure better reflects representativeness. Our findings are consistent with prior studies that show that individual internal pages carry fewer trackers than landing pages [8]. Under uBlock Origin, targeting cookies are nearly eliminated on both homepages and internal pages, so its paired difference is near zero by construction.

L Firm-Size Controls and Multiple-Testing Correction

CCPA-subject firms are, by the statute’s revenue threshold, larger on average and may derive more revenue from data sharing, which could on its own lead to more detailed privacy policies. To test whether the disclosure gap reflects CCPA *applicability* rather than size or ad-revenue reliance, we fit a logistic regression for each key disclosure on CCPA subjectivity, adjusting for company annual revenue ($\log_{10}$, from the business-intelligence source used for subjectivity in §3.1) and a proxy for ad-revenue reliance (each site’s third-party Targeting tracking intensity), over the $N = 816$ sites with available revenue data (Table 7, panel A). CCPA subjectivity

remains a strong, positive predictor of the opt-out, access, and deletion disclosures (all $p < 0.001$), whereas company revenue is not a significant predictor of the opt-out ($p = 0.55$) and is at most weakly associated with the other disclosures.

We complement this with a size-matched comparison restricted to organizations above the statute’s \$25M revenue threshold ($N = 563$: 528 subject, 35 exempt), contrasting CCPA-Subject firms with large but exempt organizations such as nonprofits and government agencies (Table 7, panel B). Even at comparable size, CCPA-Subject firms disclose opt-out mechanisms far more often (77% vs. 46%), with comparable gaps for the rights to access and delete data (85% vs. 60%). Together, these results indicate that the disclosure gap reflects CCPA applicability rather than firm size or ad-revenue reliance alone, though as an observational comparison it cannot establish strict causation. Table 8 further reports multiple-testing-adjusted p -values for all 25 tests; every main policy finding survives the stricter Holm–Bonferroni correction.

M Multiple Hypothesis Corrections

To account for multiple comparisons which we perform in §4, we treat all 25 CCPA-Subject versus CCPA-Not-Subject tests (16 policy and 9 cookie) as a single family and report both Benjamini–Hochberg and Holm–Bonferroni adjusted p -values in Table 8. We base our conclusions on the stricter Holm correction, under which all main policy findings remain significant.

N Legal Basis and Mapping

The California Consumer Privacy Act (CCPA) and its amendment, the California Privacy Rights Act (CPRA), establish explicit disclosure obligations and consumer rights that businesses must incorporate into their privacy policies. To ensure that our structured LLM prompt aligns with these legal requirements, we map each field in the schema to the corresponding statutory provision, which we then validate through an expert legal review. Table 9 presents the detailed alignment between our prompt fields and the relevant CCPA/CPRA sections.

Legal Validation of the Rubric. The alignment in Table 9 was validated through a structured expert-review process. The authors first manually constructed an initial mapping of each CCPA/CPRA provision to a corresponding compliance dimension in our rubric. Then, the mapping was reviewed by an external legal expert specializing in California privacy regulation, an attorney holding a Juris Doctor (JD) with over 15 years of experience in privacy law and regulatory compliance spanning both industry privacy programs and government privacy oversight, currently serving at a public-sector regulatory organization. The expert reviewed each provision-to-dimension mapping explicitly, confirmed that the alignment correctly reflected statutory requirements, and suggested minor interpretive refinements, which we incorporated: (i) for sensitive personal information, that regulated entities must additionally ensure reasonable security of such data (§1798.100(e)); and (ii) for the deletion right, that it is subject to limited statutory exceptions (e.g., completing a transaction or complying with a legal obligation, §1798.105(d)) and that businesses must respond within 45 days (§1798.130(a)(2)(A)). In addition, one of the co-authors has worked

Table 8: Raw and multiple-testing-adjusted p -values for all 25 reported Subject vs. Not-Subject tests (16 policy, 9 cookie), treated as a single family. BH: Benjamini–Hochberg adjusted p -value (controls the false-discovery rate, FDR); Holm: Holm–Bonferroni adjusted p -value (controls the family-wise error rate, FWER), following O’Connor et al. [87]. The last two columns mark significance at $\alpha = 0.05$ after adjustment; we base our conclusions on the Holm column.

Family	Test	p -value	BH adj. p	Holm adj. p	BH*	Holm*
policy	rubric_usability	3.6×10^{-19}	9.0×10^{-18}	9.0×10^{-18}	✓	✓
policy	claim_m_offline	1.2×10^{-17}	1.5×10^{-16}	2.8×10^{-16}	✓	✓
policy	rubric_completeness	1.2×10^{-14}	9.7×10^{-14}	2.7×10^{-13}	✓	✓
cookie	3p_Performance	5.8×10^{-14}	3.6×10^{-13}	1.3×10^{-12}	✓	✓
policy	rubric_accuracy	1.2×10^{-11}	6.2×10^{-11}	2.6×10^{-10}	✓	✓
policy	disc_opt_out	1.1×10^{-10}	4.6×10^{-10}	2.2×10^{-9}	✓	✓
policy	disc_right_to_access	5.3×10^{-10}	1.9×10^{-9}	1.0×10^{-8}	✓	✓
policy	disc_right_to_delete	1.2×10^{-9}	3.7×10^{-9}	2.1×10^{-8}	✓	✓
policy	claim_honors_gpc	2.5×10^{-8}	6.9×10^{-8}	4.3×10^{-7}	✓	✓
cookie	count_Functional	1.4×10^{-7}	3.6×10^{-7}	2.3×10^{-6}	✓	✓
cookie	3p_Functional	3.1×10^{-7}	7.1×10^{-7}	4.7×10^{-6}	✓	✓
cookie	3p_Targeting	2.0×10^{-6}	4.1×10^{-6}	2.7×10^{-5}	✓	✓
policy	disc_retention_period	3.3×10^{-6}	6.3×10^{-6}	4.3×10^{-5}	✓	✓
policy	claim_sells_data	0.001	0.002	0.016	✓	✓
cookie	count_Necessary	0.006	0.010	0.066	–	–
cookie	3p_Necessary	0.035	0.055	0.352	–	–
cookie	count_Performance	0.037	0.055	0.352	–	–
policy	disc_data_collected	0.072	0.100	0.573	–	–
policy	disc_purpose_of_collection	0.082	0.108	0.576	–	–
cookie	3p_overall	0.145	0.176	0.869	–	–
policy	claim_m_online	0.148	0.176	0.869	–	–
policy	disc_data_shared	0.195	0.221	0.869	–	–
policy	claim_shares_3p	0.259	0.282	0.869	–	–
cookie	count_Targeting	0.562	0.585	1.000	–	–
policy	claim_respects_dnt	0.830	0.830	1.000	–	–

directly with government agencies on privacy regulations and contributed to continuous legal interpretation. This process validates the legal rubric itself, that each dimension correctly reflects the statute, and not the LLM application of the rubric, which is impractical to be expert-validated at scale. The correctness of the LLM’s *application* of the rubric is instead evaluated separately through manual output review and inter-model agreement (§3.2.3).

O Full LLM Prompt

For transparency and reproducibility, we provide the complete instruction prompt that guided the large language model (LLM) in our study below. This prompt encodes both a normative framework derived from the CCPA, and a practical data-extraction schema that allows for large-scale, automated, and reproducible auditing of privacy policies. The prompt is designed with three guiding principles: (1) *statutory alignment*, meaning every field corresponds directly to a disclosure or right enumerated in the CCPA; (2) *structured reproducibility*, meaning outputs conform to a single fixed JSON schema with deterministic key ordering, strict types, and no extraneous content; and (3) *evidence-based interpretability*, meaning every non-trivial flag or score must be accompanied by textual justification grounded in the policy itself. These principles ensure that outputs are both legally meaningful and auditable by human reviewers.

The first two fields, `online_data_practices` and `offline_data_practices`, capture concise natural-language summaries of how the policy describes data collection channels. This dual distinction reflects the statutory scope of the CCPA, which covers information collected “online and offline” (§1798.140(v)(1)). Online practices include cookies, SDKs, analytics tools, ad-tech integrations, or registration forms embedded in websites or apps. Offline practices

capture in-store purchases, customer service interactions, loyalty programs, events, or any physical-world collection. By requiring explicit summaries, and defaulting to “Not mentioned.” when absent, the schema prevents silent omissions.

The central block, `rubric_assessment`, quantitatively evaluates the policy’s presentation of consumer rights and disclosure obligations. It includes:

- *completeness_score* (0–3): Does the policy enumerate core statutory rights—access (§1798.110), deletion (§1798.105), opt-out of sale or sharing (§1798.120), and (under CPRA) correction (§1798.106) and sensitive PII limitation (§1798.121)? Does it explain how to exercise them? A score of 0 reflects total absence; 3 indicates comprehensive coverage with actionable mechanisms.
- *usability_score* (0–3): How easy are the mechanisms to use? We assess the availability of multiple clear channels (e.g., toll-free number, web portal, email), the presence of explicit labels (e.g., “Do Not Sell or Share My Personal Information”), guidance on verification, timelines for responses, and any references to appeal processes. This corresponds to procedural requirements in §1798.130(a)(1).
- *accuracy_score* (0–3): Are statutory terms used correctly and up to date? For example, policies must distinguish “selling” from “sharing” for cross-context behavioral advertising, acknowledge opt-out signals such as Global Privacy Control, and avoid outdated claims such as “we do not honor CCPA rights.” Misstatements reduce the score.

Each score is paired with a mandatory free-text rationale, ensuring that numeric judgments are traceable to policy text. This block

Table 9: Mapping of LLM-Prompt JSON output Fields to specific CCPA/CPRA Provisions

Field	Legal Reference (Cal. Civ. Code)	Rationale
categories_of_personal_information_collected	§1798.130(a)(5)(B)(i)	Requires disclosure in the privacy policy of categories of personal information collected about consumers.
categories_of_sensitive_personal_information	§1798.100(a)(2), §1798.100(e), §1798.121	If sensitive personal information is collected, businesses must disclose the categories and purposes for collection, and whether it is sold or shared. CPRA establishes additional disclosure and limitation rights for sensitive personal information. Regulated entities must also ensure reasonable security of sensitive personal information.
purpose_of_collection	§1798.130(a)(5)(B)(iii)	Businesses must state the business or commercial purpose for collecting or sharing personal information.
categories_of_sources	§1798.130(a)(5)(B)(ii)	Requires disclosure of categories of sources from which personal information is collected.
categories_of_third_parties	§1798.130(a)(5)(B)(iv)	Requires disclosure of categories of third parties with whom personal information is shared.
sale_of_personal_information	§1798.130(a)(5)(C)(i)	Businesses must disclose categories of personal information sold, or affirmatively state if no sale occurred in the past 12 months.
sharing_of_personal_information	§1798.130(a)(5)(C)(i)	Under CPRA, “sharing” for cross-context behavioral advertising must be disclosed in the same manner as “sales.”
disclosure_for_business_purpose	§1798.130(a)(5)(C)(ii)	Requires disclosure of categories of personal information disclosed for a business purpose in the past 12 months.
right_to_know	§1798.110	Consumers have a right to know what personal information is collected, used, or disclosed. Businesses must disclose this right and provide mechanisms to exercise it.
right_to_delete	§1798.105	Grants consumers the right to request deletion of their personal information (subject to limited exceptions such as completing a transaction or complying with legal obligations). Businesses must disclose this right and the process to exercise it, and respond within 45 days.
right_to_correct	§1798.106	CPRA establishes the right to request correction of inaccurate personal information; businesses must disclose this right and provide mechanisms to exercise it.
right_to_opt_out	§1798.120	Consumers have the right to opt out of the sale or sharing of personal information. Businesses must provide clear notice of this right and mechanisms to exercise it.
right_to_limit_sensitive_personal_information	§1798.121(a)	Consumers may limit use and disclosure of sensitive personal information to purposes reasonably necessary to perform services or provide goods; businesses must enable this right through a “Limit the Use of My Sensitive Personal Information” link.
non_discrimination	§1798.125(a)	Prohibits discrimination (e.g., denial of goods/services or unequal pricing) against consumers who exercise their CCPA rights, though businesses may charge different prices if reasonably related to the value provided by consumer data.
financial_incentives	§1798.125(b)	Businesses may offer financial incentives for collection, sale, or retention of personal information; must provide notice of material terms and allow consumers to opt in (with revocable consent) or opt out. Cannot be unjust, unreasonable, coercive, or usurious.
authorized_agent	§1798.135(e)	Consumers may designate an authorized agent to exercise rights on their behalf; businesses must honor such requests pursuant to Attorney General regulations.
methods_for_requests	§1798.130(a)(1)	Requires businesses to provide two or more designated methods (e.g., toll-free number and website/webform) to submit consumer rights requests.
data_retention	§1798.100(a)(3)	Requires disclosure of retention period for each category of personal information (including sensitive personal information), or criteria used to determine it. Personal information must not be retained longer than reasonably necessary for disclosed purposes.
policy_last_updated	§1798.130(a)(5)	Privacy policies must be updated at least once every 12 months to reflect current practices and disclosures.

also includes a `policy_contradiction` flag to capture internal inconsistencies (e.g., a policy that both claims to “never share” and later describes sharing), and a `disclosure_map` of booleans marking whether the policy explicitly discloses each statutory element: categories collected (§1798.130(a)(5)(B)(i)), categories of sources (§1798.130(a)(5)(B)(ii)), purposes of collection (§1798.130(a)(5)(B)(iii)), categories of third parties (§1798.130(a)(5)(B)(iv)), retention periods (§1798.100(a)(3)), and rights (access, delete, opt-out). By binarizing disclosures, we ensure comparability across policies.

Behavioral Claims. While disclosures capture what a policy states, they may not reveal how the business actually behaves. To bridge this gap, the schema includes a `behavioral_claims` block. Each claim is expressed as `true`, `false`, or “unspecified”, covering:

- signal recognition (honors GPC, respects DNT),
- cookie and consent handling (sets cookies before consent, after rejection, deletes cookies upon rejection, uses tracking only after consent), and

- data transfer practices (sells data, shares with third parties, shares for cross-context behavioral advertising).

Every flag must be accompanied by a justification quoting or paraphrasing the nearest relevant clause, or—if absent—an explicit statement that “No explicit statement found; flag set to unspecified.” This ensures that unspecified values are not silent defaults but traceable to an absence of evidence. This design makes the schema robust to both over-claiming (hallucinated compliance) and under-claiming (false negatives).

Cookies and Statutory Mentions. Because cookies are a central mechanism of online tracking, the schema includes dedicated fields for whether cookies are mentioned (`cookie_practices_mentioned`) and for an excerpt summarizing the discussion (`cookie_practices_excerpt`). This ensures that cookie-related practices are consistently identified even if not linked to explicit rights. A parallel field captures whether the policy explicitly names the CCPA or CPRA, and if so, records a concise excerpt (`mentions_ccpa`, `mentions_ccpa_excerpt`). These allow us to distinguish between policies

that acknowledge California-specific legal frameworks and those that do not.

Table 9 provides the full mapping of each of our LLM-prompt fields with specific CCPA guidelines. By enforcing a schema that is tightly mapped to statute, the LLM output is not only machine-parseable but also legally interpretable.

```

def build_prompt(domain: str, policy_text: str) -> str:
    """
    Returns a detailed instruction prompt for the LLM with clear scoring rubrics,
    definition of each metric/flag, and a strict JSON schema to follow.
    Also instructs to always provide non-empty justifications.
    """
    return f"""
You are a privacy compliance analyst evaluating a privacy policy strictly under the California Consumer Privacy Act (CCPA) and related U.S.
state privacy concepts (CPRA updates included). You must rely ONLY on the policy text provided below--no external knowledge or
assumptions.

Analyze the policy for: {domain}

# Output Requirements
Return one JSON object matching this exact schema and types:
{
  "online_data_practices": "string (brief summary or 'Not mentioned.').",
  "offline_data_practices": "string (brief summary or 'Not mentioned.').",
  "rubric_assessment": {
    "completeness_score": 0-3,
    "completeness_reason": "string",
    "usability_score": 0-3,
    "usability_reason": "string",
    "accuracy_score": 0-3,
    "accuracy_reason": "string",
    "disclosure_map": {
      "data_collected": true/false,
      "data_shared": true/false,
      "purpose_of_collection": true/false,
      "retention_period": true/false,
      "right_to_access": true/false,
      "right_to_delete": true/false,
      "opt_out": true/false
    }
  },
  "behavioral_claims": {
    "honors_gpc": true/false/"unspecified",
    "respects_dnt": true/false/"unspecified",
    "sets_cookies_before_consent": true/false/"unspecified",
    "sets_cookies_after_rejecting_consent": true/false/"unspecified",
    "deletes_cookies_on_rejection": true/false/"unspecified",
    "uses_tracking_only_after_consent": true/false/"unspecified",
    "sells_data": true/false/"unspecified",
    "shares_with_third_parties": true/false/"unspecified",
    "justifications": {
      "honors_gpc": "1-2 sentences. NEVER 'unspecified'. If flag is 'unspecified', explicitly say 'No explicit statement found; flag set to
unspecified.' and cite the nearest relevant line(s).",
      "respects_dnt": "1-2 sentences. NEVER 'unspecified'. If flag is 'unspecified', explicitly say 'No explicit statement found; flag set to
unspecified.' and cite the nearest relevant line(s).",
      "sets_cookies_before_consent": "1-2 sentences. NEVER 'unspecified'. If flag is 'unspecified', explicitly say 'No explicit statement
found; flag set to unspecified.' and cite the nearest relevant line(s).",
      "sets_cookies_after_rejecting_consent": "1-2 sentences. NEVER 'unspecified'. If flag is 'unspecified', explicitly say 'No explicit
statement found; flag set to unspecified.' and cite the nearest relevant line(s).",
      "deletes_cookies_on_rejection": "1-2 sentences. NEVER 'unspecified'. If flag is 'unspecified', explicitly say 'No explicit statement
found; flag set to unspecified.' and cite the nearest relevant line(s).",
      "uses_tracking_only_after_consent": "1-2 sentences. NEVER 'unspecified'. If flag is 'unspecified', explicitly say 'No explicit statement
found; flag set to unspecified.' and cite the nearest relevant line(s).",
      "sells_data": "1-2 sentences. NEVER 'unspecified'. If flag is 'unspecified', explicitly say 'No explicit statement found; flag set to
unspecified.' and cite the nearest relevant line(s).",
      "shares_with_third_parties": "1-2 sentences. NEVER 'unspecified'. If flag is 'unspecified', explicitly say 'No explicit statement found;
flag set to unspecified.' and cite the nearest relevant line(s).",
    }
  },
  "cookie_practices_mentioned": true/false/"unspecified",
  "cookie_practices_excerpt": "string (<= 600 chars). If unspecified, say: 'No explicit mention found.'",
  "mentions_ccpa": true/false/"unspecified",
  "mentions_ccpa_excerpt": "string (<= 600 chars). If unspecified, say: 'No explicit mention found.'",
  "contacts": {
    "opt_out": {
      "form_urls": ["..."],
      "emails": ["..."],
      "phone_numbers": ["..."],
      "other_urls": ["..."]
    },
    "access_or_delete": {
      "form_urls": ["..."],

```



```

    "emails": ["..."],
    "phone_numbers": ["..."],
    "other_urls": ["..."]
  }
},
"contacts_flat": [
  {
    "type": "form_url|email|phone|other_url",
    "for": "opt_out|access|delete|access_delete|general_privacy",
    "value": "string",
    "label": "string or empty"
  }
]
}
}

## Section A - Policy Scope Categorization
- online_data_practices: Briefly summarize policy text on web/app tracking and collection (e.g., cookies, pixels, SDKs, analytics, ad tech, web forms, account signup). If not present, return "Not mentioned."
- offline_data_practices: Briefly summarize policy text on in-store collection, call centers, paper forms, events, or other in-person channels. If not present, return "Not mentioned."

## Section B - Policy Quality Assessment (Scored 0-3)
Score using only what the policy explicitly states.

### 1) completeness_score (0-3)
Assess whether the policy mentions and explains consumer rights central to CCPA and how to exercise them.
- What to look for: Access/know; deletion; opt-out of sale/share/targeted advertising; (nice-to-have but not required: correction, portability, non-discrimination, appeal).
- Scoring guide:
  - 0: No meaningful mention of rights or how to exercise them.
  - 1: Vague rights mention, minimal specifics, unclear processes.
  - 2: Rights identified with at least some concrete instructions (e.g., link/email/form/phone), but gaps remain (e.g., missing one core right or unclear verification).
  - 3: Rights clearly listed (access/know, delete, opt-out of sale/share/targeted advertising), with actionable mechanisms (webform/email/phone link) and basics on verification, timelines, and scope.

### 2) usability_score (0-3)
Evaluate how actionable the mechanisms are.
- What to look for: Dedicated links/buttons, DSAR portals, emails, phone numbers, clear steps, eligibility/verification guidance, response timelines, required information.
- Scoring guide:
  - 0: No method to act; purely informational.
  - 1: A method exists but is hard to find or ambiguous (e.g., generic support email, broken/missing link).
  - 2: Clear method(s) with some guidance; minor friction or missing details.
  - 3: Multiple clear methods + step-by-step clarity (verification, timelines, exceptions, appeal) and unambiguous labels (e.g., "Do Not Sell or Share My Personal Information").

### 3) accuracy_score (0-3)
Evaluate legal/terminology correctness and internal consistency.
- What to look for: Correct use of terms (e.g., "sale" includes broad consideration; "share" for targeted advertising; "verified consumer"; "sensitive personal information" limits; "household"/"personal information" definitions), avoidance of outdated/incorrect claims, correct opt-out signal references (e.g., GPC).
- Scoring guide:
  - 0: Clearly incorrect or misleading legal statements.
  - 1: Several inaccuracies or outdated framing; ambiguous on critical terms.
  - 2: Mostly accurate with minor issues/ambiguities.
  - 3: Accurate, current, and aligned with CCPA/CPRA language; exceptions and scope are described correctly.

### disclosure_map (booleans)
Mark true only if the policy explicitly discloses the item.
- data_collected: Lists categories collected (e.g., identifiers, geolocation, internet activity).
- data_shared: States data is shared with third parties (including for targeted advertising/cross-context behavioral advertising).
- purpose_of_collection: Explains why data is collected (e.g., service provision, security, marketing, analytics).
- retention_period: States a duration/criteria for retention.
- right_to_access: Explains the right to know/access and how to exercise it.
- right_to_delete: Explains the right to delete and how to exercise it; may list exceptions.
- opt_out: Provides a mechanism to opt out of sale or share/targeted advertising (e.g., DNSMPI page, "Your Privacy Choices" link, opt-out signal).

## Section C - Semantic Behavior Claims (True/False/"unspecified")
Use true/false ONLY if the policy explicitly supports the claim. Otherwise use "unspecified".
For every behavioral flag, provide a non-empty justification:
- If explicit: quote/paraphrase the line(s) and cite the section title if available.
- If not explicit: write, "No explicit statement found; flag set to unspecified." and include the nearest relevant line(s) that discuss cookies/tracking/opt-out signals/third-party sharing, if any.

## Section D - Cookie & CCPA Mentions + Contact Extraction

```

```
Strict rules:
- Use true/false ONLY if explicit. Otherwise use "unspecified".
- cookie_practices_mentioned = true if the policy discusses cookies (e.g., cookies, pixels, SDKs, analytics cookies) at all, regardless of consent steps.
- mentions_ccpa = true if the policy explicitly mentions "CCPA", "CPRA", "California Consumer Privacy Act", "California privacy rights" (in a legal-rights sense).
- Extract concrete contact methods for (a) opt-out of sale/share/targeted advertising, and (b) access/delete requests (right to know/delete). Put each into the appropriate bucket(s).
- Provide a flattened list in contacts_flat with the intended purpose (for) and a guessed label if present (e.g., "Your Privacy Choices", "Do Not Sell or Share").
- If no contacts are found for a category, return empty arrays.

## Important Rules
- Base everything only on the provided policy text.
- Do not assume. If unclear or absent, use false (for disclosure_map booleans) or "unspecified" (for behavioral flags).
- Keep summaries concise, specific, and neutral.
- Return only the JSON object--no prose before or after.

===== BEGIN POLICY TEXT =====
{policy_text}
===== END POLICY TEXT =====
"".strip()
```